UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

Informe de Seguridad Ofensivo

PR02 – Blindando la información: gobernanza y cumplimiento

FECHA DE ENTREGA:16 DE OCTUBRE 2026

ALUMNO: DAVID CAMPOS MORADO – 183511
PROFESOR: MTRO. SERVANDO LÓPEZ CONTRERAS

Tabla de contenido

Resumen Ejecutivo....5
Inventario de Vulnerabilidades (Tabla Maestra)....5
Metodología de Evaluación....6
Hallazgos Detallados....6
Primera Bandera....6
Descripción técnica y causa raíz....6
Comprobación de los hallazgos....6
Evidencia técnica....6
Impacto y riesgo....9
Mitigaciones....9
Segunda Bandera....9
Descripción técnica y causa raíz....9
Comprobación de los hallazgos....9
Evidencia técnica....10
Impacto y riesgo....12
Mitigaciones....12
Tercera Bandera....12
Descripción técnica y causa raíz....12
Comprobación de los hallazgos....12
Evidencia técnica....12
Impacto y riesgo....14
Mitigaciones....14
Cuarta Bandera....14
Descripción técnica y causa raíz....14
Comprobación de los hallazgos....14
Evidencia técnica....14
Impacto y riesgo....15
Mitigaciones....15
Quinta bandera....16
Descripción técnica y causa raíz....16
Comprobación de los hallazgos....16
Evidencia técnica....16
Impacto y riesgo....18
Mitigaciones....18
Sexta Bandera....18
Descripción técnica y causa raíz....18
Comprobación de los hallazgos....18
Evidencia técnica....18

Impacto y riesgo.....20
Mitigaciones.....20
Séptima Bandera.....20
Descripción técnica y causa raíz.....20
Comprobación de los hallazgos.....20
Evidencia técnica.....20
Impacto y riesgo.....22
Mitigaciones.....23
Octava Bandera.....23
Descripción técnica y causa raíz.....23
Comprobación de los hallazgos.....23
Evidencia técnica.....23
Impacto y riesgo.....25
Mitigaciones.....25
Novena Bandera.....25
Descripción técnica y causa raíz.....25
Comprobación de los hallazgos.....25
Evidencia técnica.....25
Impacto y riesgo.....26
Mitigaciones.....26
Decima Bandera.....27
Descripción técnica y causa raíz.....27
Comprobación de los hallazgos.....27
Evidencia técnica.....27
Impacto y riesgo.....29
Mitigaciones.....29
Undécima Bandera.....29
Descripción técnica y causa raíz.....29
Comprobación de los hallazgos.....29
Evidencia técnica.....29
Impacto y riesgo.....30
Mitigaciones.....30
Duodécima Bandera.....30
Descripción técnica y causa raíz.....30
Comprobación de los hallazgos.....31
Evidencia técnica.....31
Impacto y riesgo.....31
Mitigaciones.....32
Decimotercera Bandera.....32

Descripción técnica y causa raíz....32
Comprobación de los hallazgos....32
Evidencia técnica....32
Impacto y riesgo....33
Mitigaciones....34
Decimocuarta Bandera....34
Descripción técnica y causa raíz....34
Comprobación de los hallazgos....34
Evidencia técnica....34
Impacto y riesgo....35
Mitigaciones....35
Decimoquinta Bandera....35
Descripción técnica y causa raíz....36
Comprobación de los hallazgos....36
Evidencia técnica....36
Impacto y riesgo....37
Mitigaciones....37
Decimosexta Bandera....37
Descripción técnica y causa raíz....37
Comprobación de los hallazgos....37
Evidencia técnica....37
Impacto y riesgo....38
Mitigaciones....38
Decimoseptima Bandera....38
Descripción técnica y causa raíz....39
Comprobación de los hallazgos....39
Evidencia técnica....39
Impacto y riesgo....40
Mitigaciones....40
Decimoctaba Bandera....40
Descripción técnica y causa raíz....41
Comprobación de los hallazgos....41
Evidencia técnica....41
Impacto y riesgo....44
Mitigaciones....44
Decimonovena Bandera....44
Descripción técnica y causa raíz....44
Comprobación de los hallazgos....44
Evidencia técnica....45

Impacto y riesgo.....46
Mitigaciones.....46
Vigésima Bandera.....47
Descripción técnica y causa raíz.....47
Comprobación de los hallazgos.....47
Evidencia técnica.....47
Impacto y riesgo.....49
Mitigaciones.....49
Análisis de Cadena de Ataque.....50
Conclusiones y Recomendaciones Prioritarias.....50

Resumen Ejecutivo

El presente informe documenta el resultado de la evaluación de seguridad ofensiva realizada sobre la organización ficticia INTERAFAS, responsable de servicios de infraestructura crítica, dentro del entorno controlado INTERAFAS-LAB. Durante el ejercicio se identificaron, comprobaron y documentaron veinte vulnerabilidades de diversa naturaleza y criticidad, recopilando las correspondientes banderas (flags), evidencias técnicas, logs y elementos de contexto necesarios para determinar causa, impacto y posible relación dentro de cadenas de ataque.

Las vulnerabilidades abarcan desde exposiciones de información sensible y malas configuraciones de servidor, hasta fallos críticos de control de acceso (IDOR, escalamiento de privilegios), inyección SQL ciega, Cross-Site Scripting almacenado, Path Traversal, fallos en la gestión de sesiones, manipulación de lógica de negocio en pagos, y vulnerabilidades de alto impacto en el entorno de Tecnologías de la Operación (OT), incluyendo verificación débil de autenticidad de firmware, violación del principio de mínimo privilegio en roles de mantenimiento y modificación no autorizada de parámetros operacionales críticos.

El análisis demuestra que una vulnerabilidad aparentemente aislada puede formar parte de una cadena de ataque que evoluciona desde el reconocimiento técnico hasta el compromiso de la integridad del proceso físico. Se proponen mitigaciones específicas, técnicamente viables y alineadas con buenas prácticas (ISO/IEC 27001, NIST SP 800-82, NIST SP 800-193 y MITRE ATT&CK for ICS).

Este informe constituye el entregable 02 del proyecto PR02 y alimenta directamente los análisis de gobernanza (ISO 27001), el Plan de Comunicación de Crisis y el Plan de Respuesta ante Incidentes.

Inventario de Vulnerabilidades (Tabla Maestra)

A continuación, se presenta la tabla maestra con las veinte vulnerabilidades identificadas, conforme al criterio PR02-03 de la rúbrica de evaluación.

ID	Identificador de Bandera	Título / Vulnerabilidad	Componente	Categoría	Riesgo
01	UPSLP_CNOIV-OPEN-DOOR-01	Directory Listing + robots.txt	Servidor Web	Info Disclosure	Medio
02	UPSLP_CNOIV-LOOK-CLOSER-02	Exposición endpoints Frontend	Frontend / JS	Info Disclosure	Medio
03	UPSLP_CNOIV-NOT-YOURS-03	IDOR en Expedientes	Portal Ciudadano	Broken Access Control	Crítico
04	UPSLP_CNOIV-OLD-MEMORIES-04	Archivo residual .bak	Servidor Web	Info Disclosure	Medio
05	UPSLP_CNOIV-TOO-MUCH-INFO-05	Error handling verbose	exportar.php	Info Disclosure	Medio
06	UPSLP_CNOIV-WRONG-ROLE-06	Privilege Escalation (cookie)	Gestión Proveedores	Broken Access Control	Crítico
07	UPSLP_CNOIV-SILENT-ANSWER-07	Blind SQL Injection	validar-referencia.php	Injection	Crítico
08	UPSLP_CNOIV-STORED-WORDS-08	Stored XSS en Reportes	Reportes Ciudadanos	XSS	Alto
09	UPSLP_CNOIV-TOO-DEEP-09	Path Traversal / LFI	descargar-documento.php	Path Traversal	Crítico
10	UPSLP_CNOIV-WHO-ARE-YOU-10	Session Replay	Gestión de Sesiones	Broken Auth	Alto
11	UPSLP_CNOIV-HIDDEN-HISTORY-11	Endpoint oculto + headers	API service-history	Info Disclosure	Medio
12	UPSLP_CNOIV-SECOND-ACCOUNT-12	IDOR en API Historial	API service-history	BOLA / IDOR	Crítico
13	UPSLP_CNOIV-PAYMENT-PATH-13	Parameter Tampering (pagos)	pago.php	Business Logic	Crítico
14	UPSLP_CNOIV-CONTRACT-LINK-14	IDOR Validación Contratos	Módulo Contrataciones	BOLA / IDOR	Crítico

15	UPSLP_CNOIV-INFRA-MAP-15	Telemetría excesiva en mapa	Servicio de mapa	Info Disclosure	Medio-Alto
16	UPSLP_CNOIV-GATEWAY-SPOOF-16	IP Spoofing (X-Forwarded-For)	Gateway operativo	Broken Access Control	Crítico
17	UPSLP_CNOIV-OPS-TOKEN-17	Token operacional en JS	HMI / Telemetría	Broken Auth / OT	Crítico
18	UPSLP_CNOIV-FIRMWARE-AUTH-18	Firmware sin firma + SHA-1	Canal Firmware	CWE-345 / CWE-327	Crítico
19	UPSLP_CNOIV-MIN-PRIV-19	Mínimo privilegio violado (OT)	HMI Asset Context	Excessive Privileges	Alto/Crítico
20	UPSLP_CNOIV-NOW-YOU-CONTROL-20	Modificación setpoint presión	Firmware / RTU-GW-07	ATT&CK T0836	Crítico

Metodología de Evaluación

La evaluación se realizó siguiendo un enfoque de caja gris dentro del entorno controlado INTERAFAS-LAB. Se combinaron técnicas de reconocimiento pasivo y activo, análisis de código del lado del cliente, manipulación de parámetros y cookies, uso de proxies (Burp Suite), herramientas de inyección automatizada (sqlmap), análisis offline de hashes (Hashcat / John the Ripper) y exploración controlada del HMI de operaciones.

Para cada hallazgo se documentó: identificador de bandera, componente afectado, categoría, descripción técnica y causa raíz, pasos de comprobación, evidencia técnica (capturas, logs, respuestas), impacto y riesgo, y mitigaciones específicas. Se priorizó la relación entre hallazgos para construir posibles cadenas de ataque.

Hallazgos Detallados

Primera Bandera

Exposición de Información Sensible mediante robots.txt y Directory Listing

Identificador de la bandera: UPSLP_CNOIV-OPEN-DOOR-01

Componente afectado: Servidor Web (Portal INTERAFAS – Puerto 8080)

Categoría: Exposición de Información Sensible / Mala Configuración del Servidor

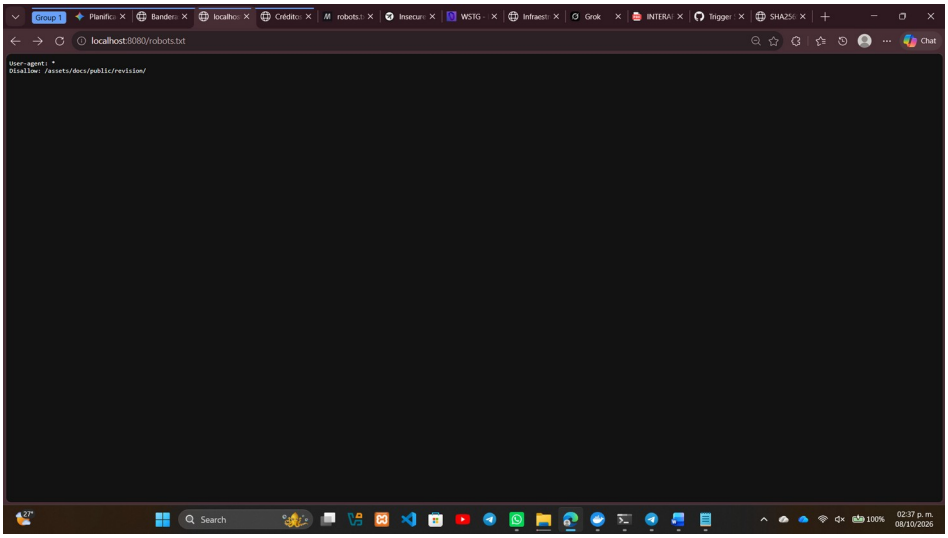
Descripción técnica y causa raíz

La vulnerabilidad surge por una mala configuración en el entorno de producción. El archivo robots.txt expone rutas internas que no deberían ser públicas (/assets/docs/public/revision/). Al navegar a esta ruta, el servidor web permite el Directory Listing debido a la ausencia de un archivo índice, lo que posibilita a cualquier usuario visualizar y descargar archivos residuales y bitácoras del despliegue. Dentro de estos archivos se localizó un archivo .env con la bandera en texto plano, junto con información de infraestructura (WEBOPS-03) y evidencias de que el equipo de administración omitió el paso de eliminación de archivos de respaldo previos al rsync final.

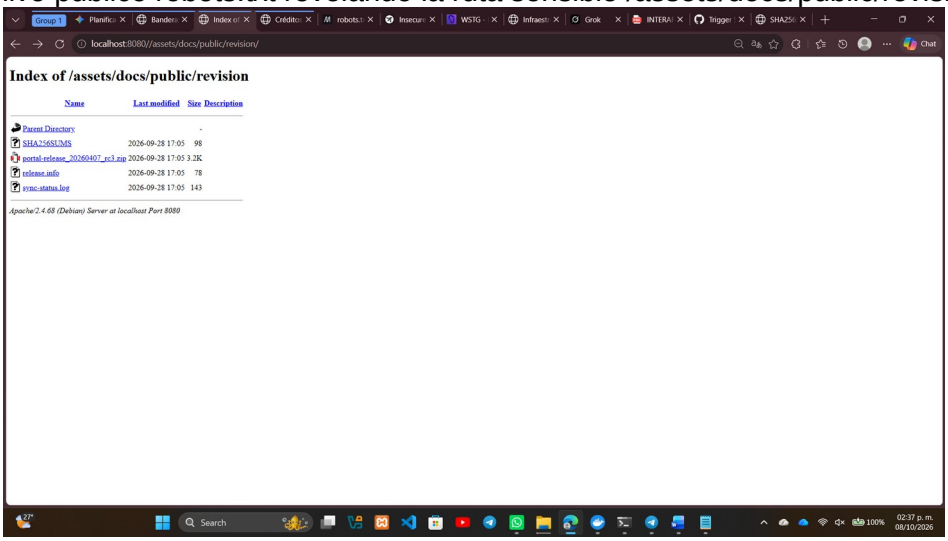
Comprobación de los hallazgos

1. Inspección de las reglas de indexación en http://localhost:8080/robots.txt.
2. Identificación de la ruta excluida /assets/docs/public/revision/.
3. Navegación forzada a dicha ruta, confirmando la vulnerabilidad de Directory Listing y listando los archivos residuales.
4. Descarga y extracción del archivo portal-release_20260407_rc3.zip.
5. Revisión de las bitácoras (rsync-20260407.log) y manuales (README-deploy), localizando el archivo release-check.env en la carpeta deploy.
6. Extracción de la bandera en la variable SMOKE_TEST_TOKEN.

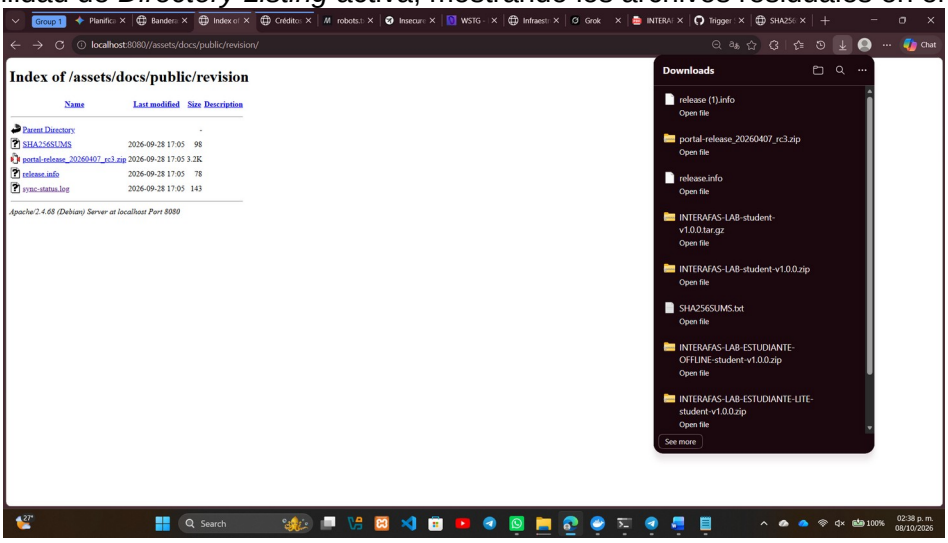
Evidencia técnica



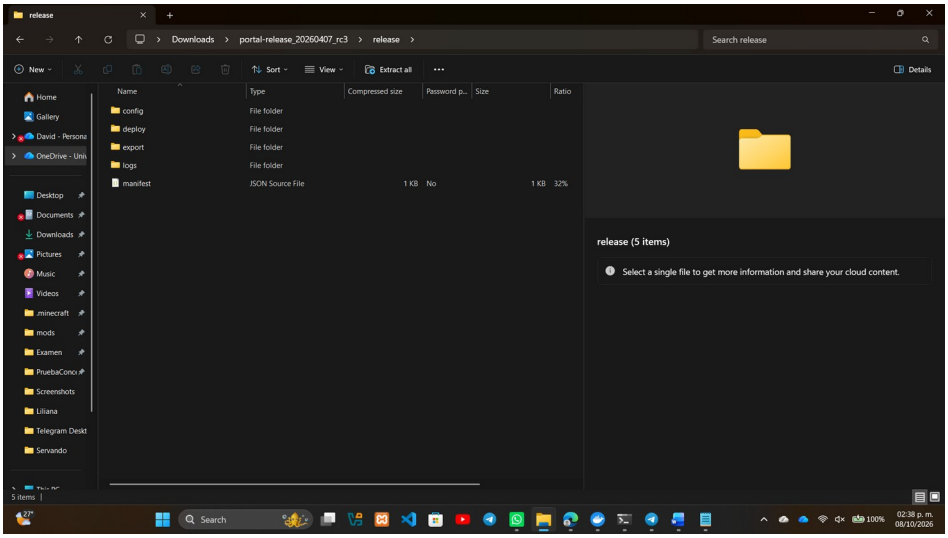
Archivo público robots.txt revelando la ruta sensible /assets/docs/public/revision/.



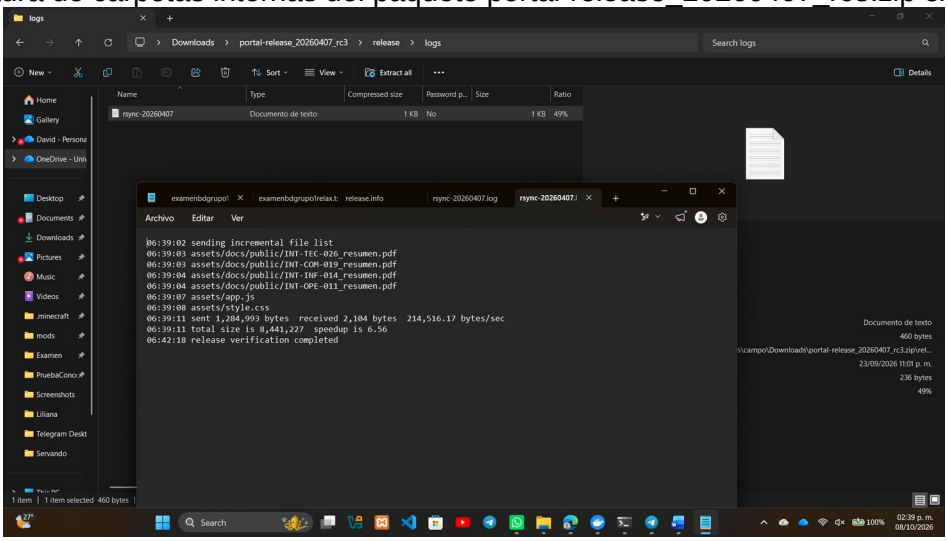
Vulnerabilidad de *Directory Listing* activa, mostrando los archivos residuales en el servidor.



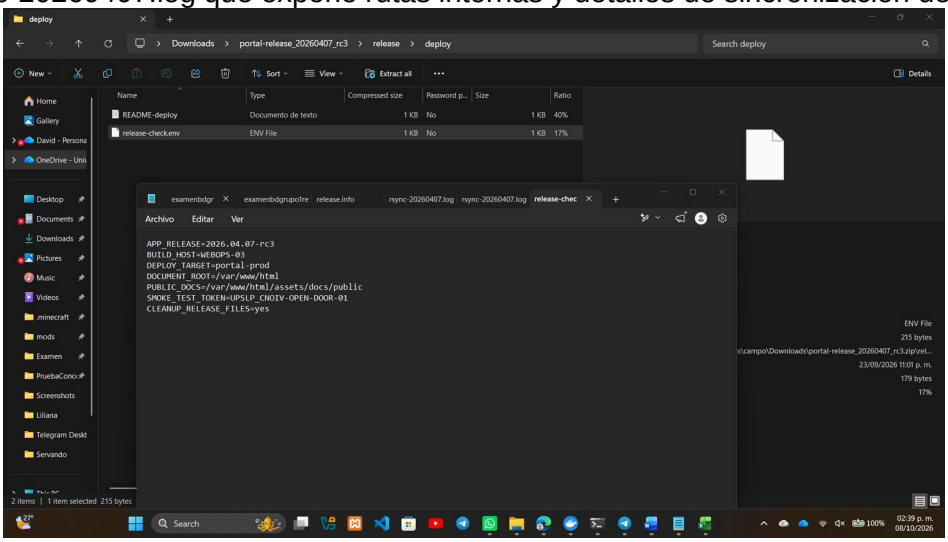
Archivo sync-status.log expuesto en el servidor web.



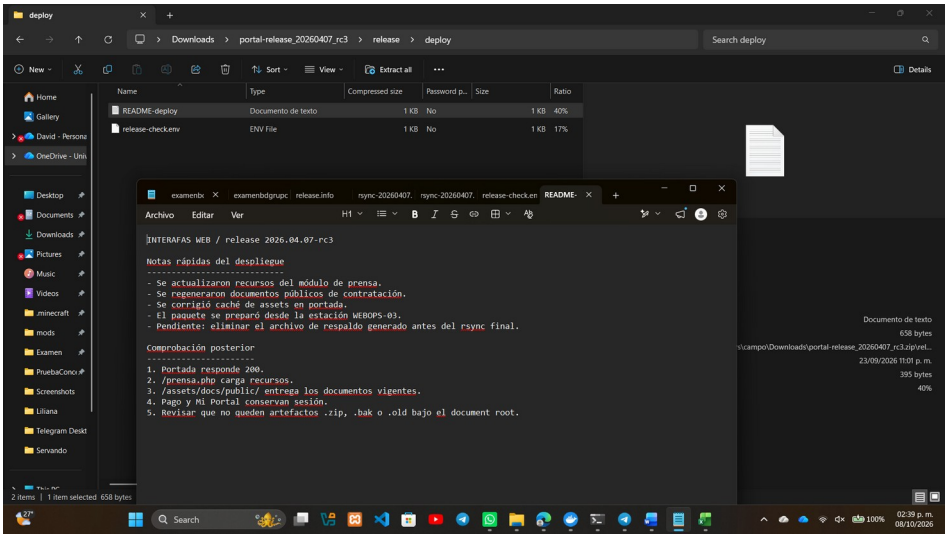
Estructura de carpetas internas del paquete portal-release_20260407_rc3.zip extraído.



Archivo rsync-20260407.log que expone rutas internas y detalles de sincronización del despliegue.



Archivo release-check.env evidenciando la bandera UPSLP_CNOIV-OPEN-DOOR-01 en la variable SMOKE_TEST_TOKEN e información de la infraestructura (WEBOPS-03).



Archivo README-deploy comprobando que el equipo de administradores omitió el paso “Pendiente: eliminar el archivo de respaldo generado antes del rsync final”.

Impacto y riesgo

Riesgo Medio. Se compromete la confidencialidad al exponer detalles de la infraestructura, rutas de archivos y tokens de validación internos. Esto facilita significativamente la fase de reconocimiento de un atacante y la preparación de vectores de ataque más sofisticados.

Mitigaciones

- Deshabilitar el Listado de Directorios modificando la configuración del servidor web (Options -Indexes en Apache, autoindex off en Nginx).
- Asegurar la sanitización del entorno de producción mediante un pipeline de CI/CD que elimine archivos .zip, .bak, .env y manuales operativos antes de la publicación.
- No incluir rutas confidenciales en el archivo robots.txt; protegerlas mediante controles de acceso y autenticación.

Segunda Bandera

Exposición de Información Sensible y Endpoints en el Frontend

Identificador de la bandera: UPSLP_CNOIV-LOOK-CLOSER-02

Componente afectado: Servidor Web / Frontend (Archivos de configuración JavaScript y Metadatos)

Categoría: Exposición de Información Sensible (Information Disclosure)

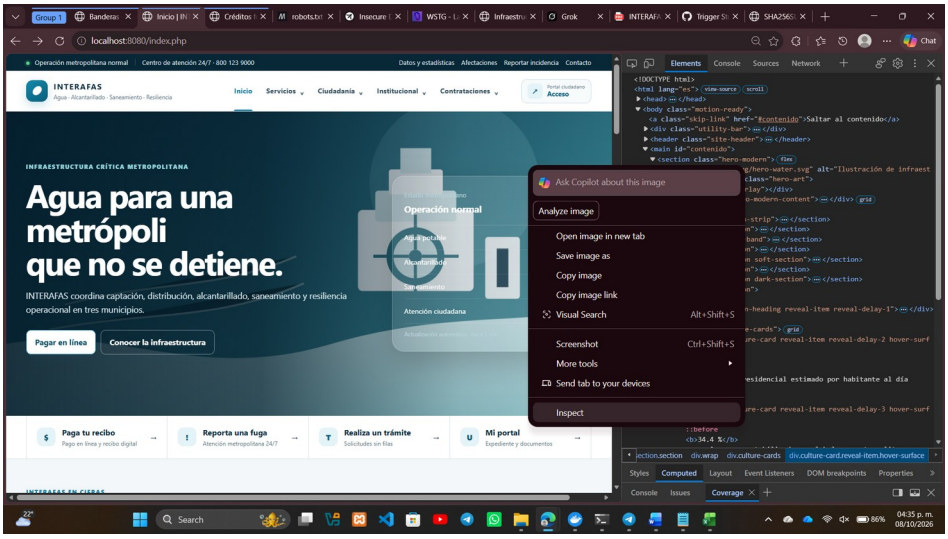
Descripción técnica y causa raíz

La aplicación web filtra información crítica a través de sus archivos del lado del cliente. El archivo runtime-config.js inyecta un objeto global (window.INTERAFAS_RUNTIME) que revela la ruta de un manifiesto de construcción interno (/assets/meta/build-manifest.php). Además, el script app.js expone rutas de la API interna (/api/account-context.php). La causa raíz es una deficiente separación de entornos, donde los metadatos de desarrollo y las rutas internas permanecen accesibles sin protección en el entorno de producción.

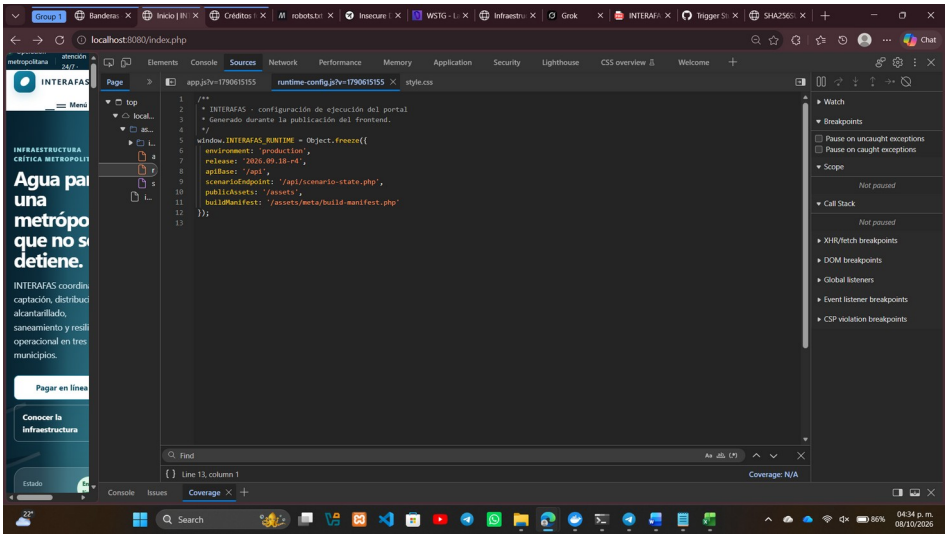
Comprobación de los hallazgos

1. Apertura de las herramientas de desarrollador (DevTools) en el Portal INTERAFAS.
2. Análisis del código en la pestaña Sources e inspección de assets/js/runtime-config.js.
3. Identificación de la ruta del manifiesto buildManifest y de llamadas a la API interna en app.js.
4. Acceso directo a http://localhost:8080/assets/meta/build-manifest.php.
5. Extracción del token de validación contenido en el bloque JSON quality_assurance.

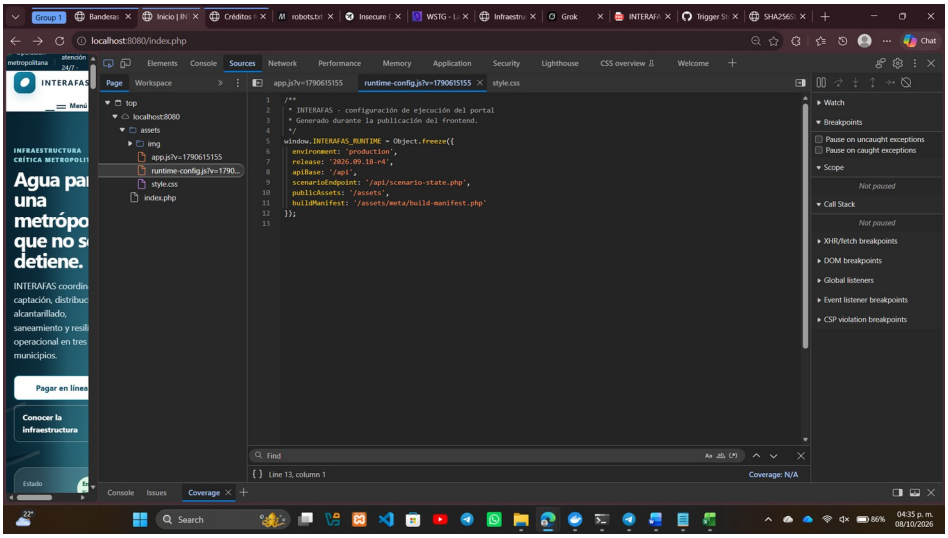
Evidencia técnica



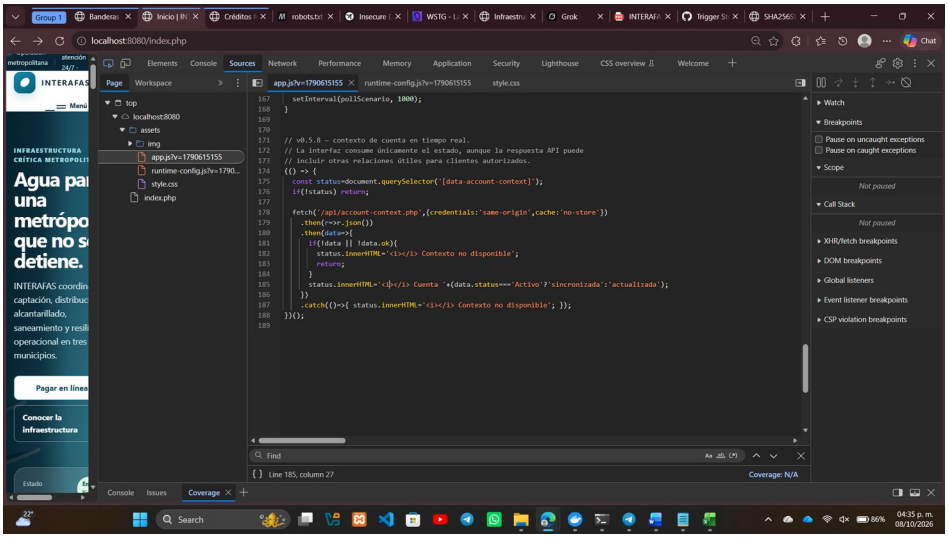
Apertura de las DevTools (Inspeccionar) en el Portal INTERAFAS.



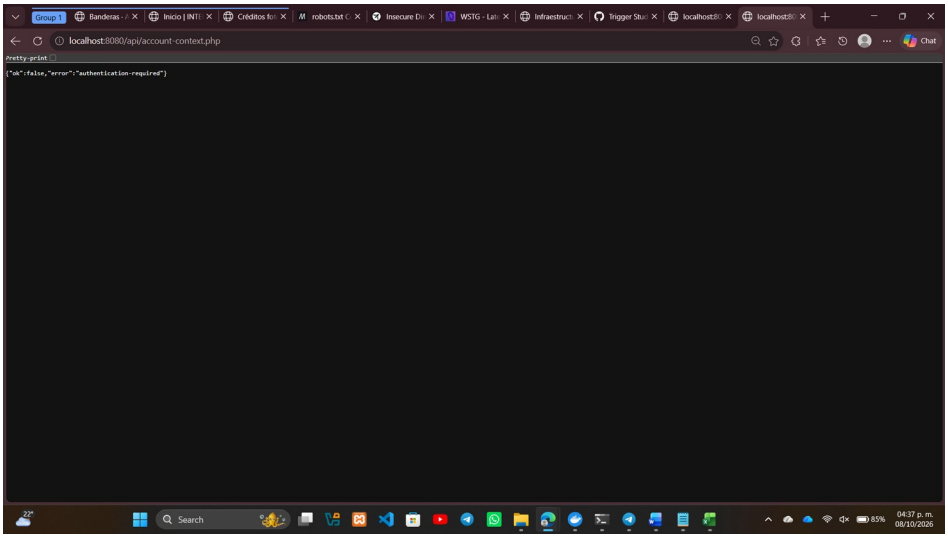
Exploración del árbol de recursos (Sources), localizando la carpeta assets/js.



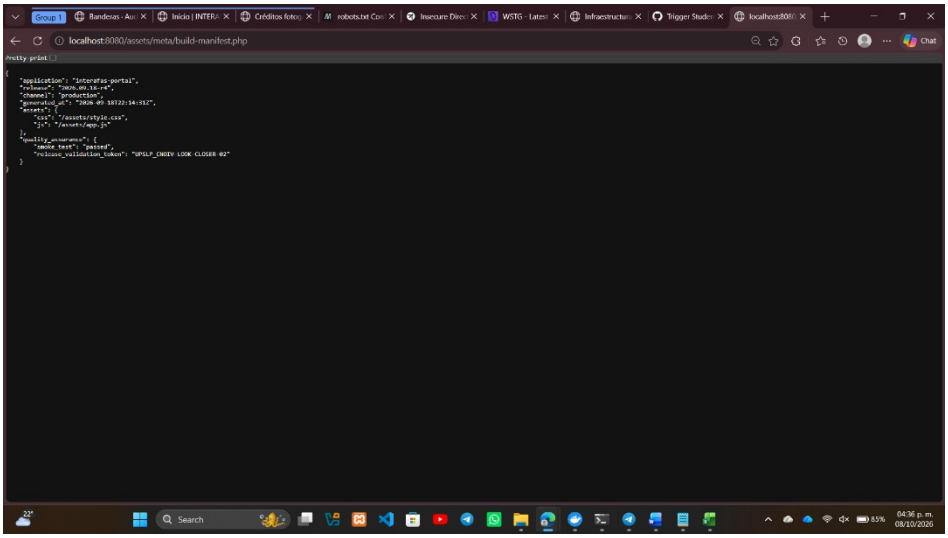
Inspección del archivo runtime-config.js, evidenciando la variable window.INTERAFAS_RUNTIME y la ruta sensible buildManifest.



Inspección del archivo app.js, donde se revelan llamadas a la API interna (/api/account-context.php) y comentarios de desarrollo.



Prueba de acceso directo al endpoint /api/account-context.php expuesto en el código.



Acceso al manifiesto build-manifest.php y obtención de la bandera UPSLP_CNOIV-LOOK-CLOSER-02.

Impacto y riesgo

Riesgo Medio. Exponer el mapa de la API, endpoints internos y tokens de construcción reduce drásticamente el esfuerzo necesario para mapear la arquitectura del sistema, abriendo vectores a posibles explotaciones posteriores.

Mitigaciones

- Ofuscar y limpiar el código Frontend mediante un proceso de construcción robusto (Webpack, Vite) que elimine comentarios, variables de depuración y rutas sensibles antes de subir a producción.
- Restringir el acceso público al directorio de metadatos (/assets/meta/) desde la configuración del servidor web, permitiendo el acceso solo a redes internas o mediante autenticación.

Tercera Bandera

Referencia Directa Insegura a Objetos (IDOR) en Expedientes

Identificador de la bandera: UPSLP_CNOIV-NOT-YOURS-03

Componente afectado: Portal Ciudadano / Módulo de Expedientes (expediente.php)

Categoría: Control de Acceso Roto (IDOR – Insecure Direct Object Reference)

Descripción técnica y causa raíz

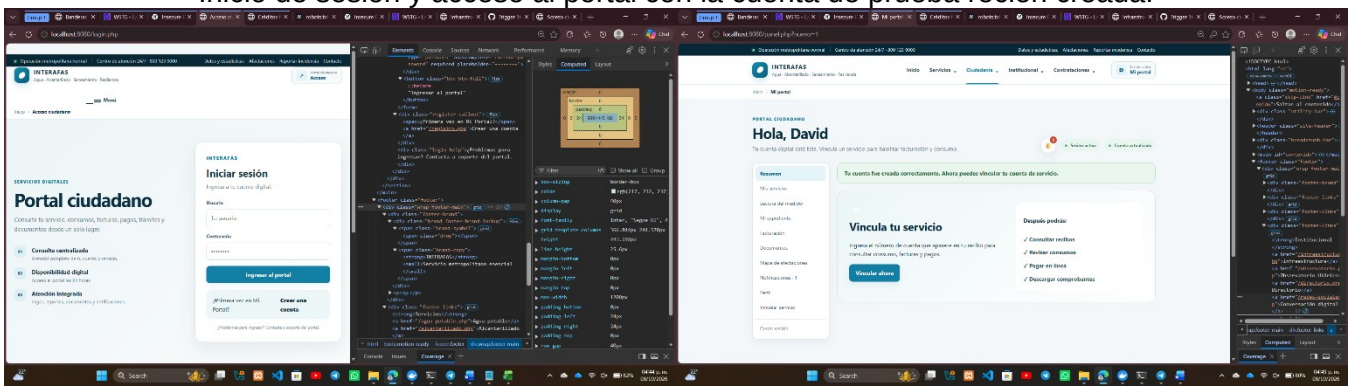
El módulo de expedientes presenta una vulnerabilidad crítica de Control de Acceso Horizontal (IDOR). El script expediente.php utiliza el parámetro id en la URL para consultar registros en la base de datos. El servidor se limita a comprobar la existencia de una sesión activa, pero omite validar que el ID de expediente solicitado pertenezca al ID del usuario autenticado. Al manipular este parámetro es posible visualizar información de cualquier usuario (nombres, direcciones, RFC y la bandera en el campo Referencia de validación).

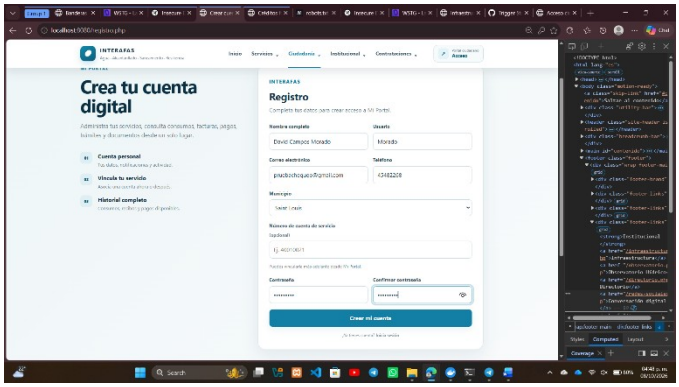
Comprobación de los hallazgos

1. Creación de una cuenta de prueba ciudadana e inicio de sesión.
2. Navegación al apartado Mi expediente (http://localhost:8080/expediente.php).
3. Modificación manual del parámetro id en la URL (ej: ?id=1, ?id=2, ?id=3).
4. Visualización de expedientes de terceros (Mariana Torres, Carlos Rivera, Alejandra Ruiz) y extracción de la bandera.

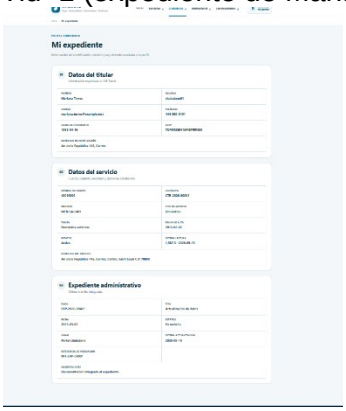
Evidencia técnica

Inicio de sesión y acceso al portal con la cuenta de prueba recién creada.

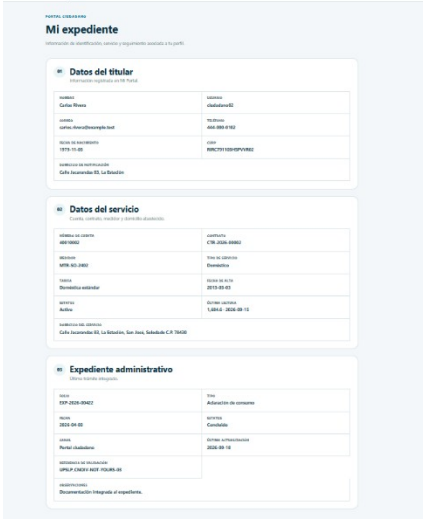




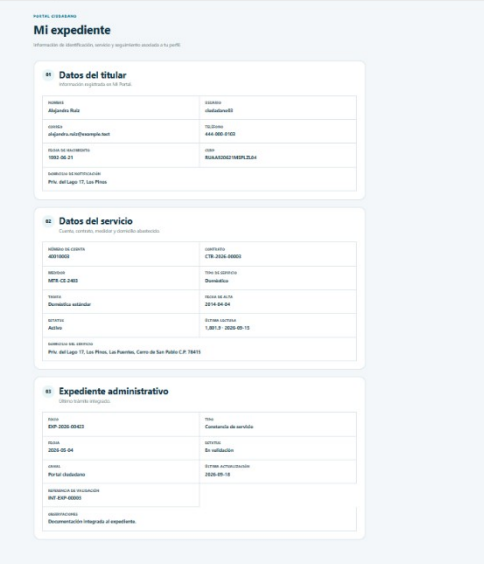
Prueba con ?id=1 (expediente de Mariana Torres).



Prueba con ?id=2 (expediente de Carlos Rivera) – Bandera visible en “Referencia de validación”.



Prueba con ?id=3 confirmando que la vulnerabilidad afecta a múltiples usuarios.



Impacto y riesgo

Riesgo Crítico. Compromete la confidencialidad y viola principios de protección de datos personales. Cualquier usuario autenticado puede realizar una enumeración secuencial y descargar la base de datos completa de expedientes de los ciudadanos.

Mitigaciones

- Implementar validación de autorización horizontal a nivel de base de datos o lógica de negocio. El servidor debe comprobar que el id solicitado esté asociado al user_id de la sesión activa antes de devolver datos.
- Sustituir los identificadores numéricos predecibles por Identificadores Únicos Universales (UUIDs) para mitigar intentos de enumeración.

Cuarta Bandera

Exposición de Código Fuente mediante Archivos Residuales (.bak)

Identificador de la bandera: UPSLP_CNOIV-OLD-MEMORIES-04

Componente afectado: Servidor Web / Módulo de Transparencia (transparencia.php.bak)

Categoría: Exposición de Información Sensible / Archivos Residuales

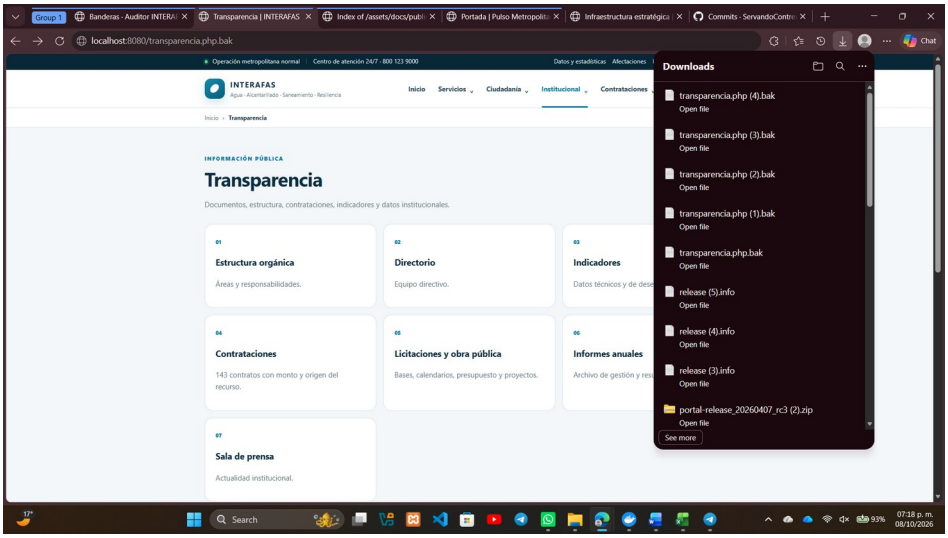
Descripción técnica y causa raíz

Se detectó la presencia de un archivo de respaldo residual (transparencia.php.bak) en el directorio raíz del servidor. Debido a la extensión .bak, el servidor web no lo interpreta como un script PHP ejecutable y lo entrega en formato de texto plano. Esto expone la lógica interna del archivo, comentarios de desarrollo, la variable $releaseValidation (que contiene la bandera) y evidencia malas prácticas de despliegue.

Comprobación de los hallazgos

1. Identificación de la página dinámica transparencia.php.
2. Realización de pruebas forzando extensiones de respaldo comunes (.bak, .old, .swp).
3. Acceso exitoso a http://localhost:8080/transparencia.php.bak.
4. Análisis del código fuente expuesto y extracción de la bandera de la variable $releaseValidation.

Evidencia técnica

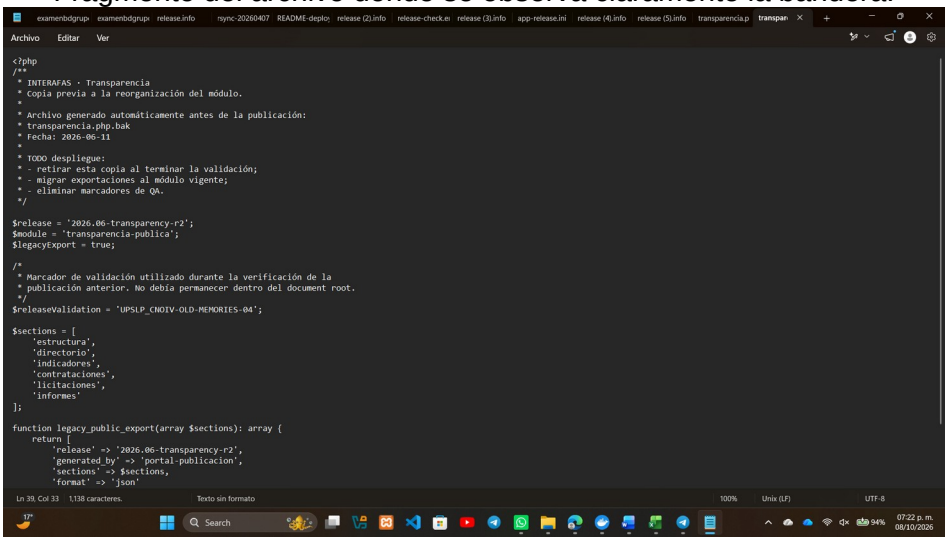


Acceso a la URL http://localhost:8080/transparencia.php.bak y visualización del código fuente en texto plano.

```
 * publicación anterior. No debía permanecer dentro del document
 */
$releaseValidation = 'UPSLP_CNOIV-OLD-MEMORIES-04';

$sections = [
```

Fragmento del archivo donde se observa claramente la bandera:



Comentarios internos del archivo que confirman que se trata de una copia residual que debió eliminarse.

Impacto y riesgo

Riesgo Medio. Compromete la confidencialidad al revelar la lógica de negocio, configuración interna y comentarios operativos que pueden utilizarse como base para vectores de ataque posteriores.

Mitigaciones

- Implementar limpieza automatizada en el pipeline (CI/CD) para eliminar cualquier archivo con extensión .bak, .old, .swp, etc., previo al despliegue.
- Configurar reglas de bloqueo en el servidor web (Apache/Nginx) para prohibir peticiones HTTP hacia extensiones de respaldo.
- Depender exclusivamente del control de versiones (Git) y prohibir la generación de respaldos manuales en el entorno de producción.

Quinta bandera

Exposición de Información Sensible mediante Manejo Improcedente de Errores

Identificador de la bandera: UPSLP_CNOIV-TOO-MUCH-INFO-05

Componente afectado: Módulo de Exportación Pública (exportar.php)

Categoría: Information Disclosure / Improper Error Handling

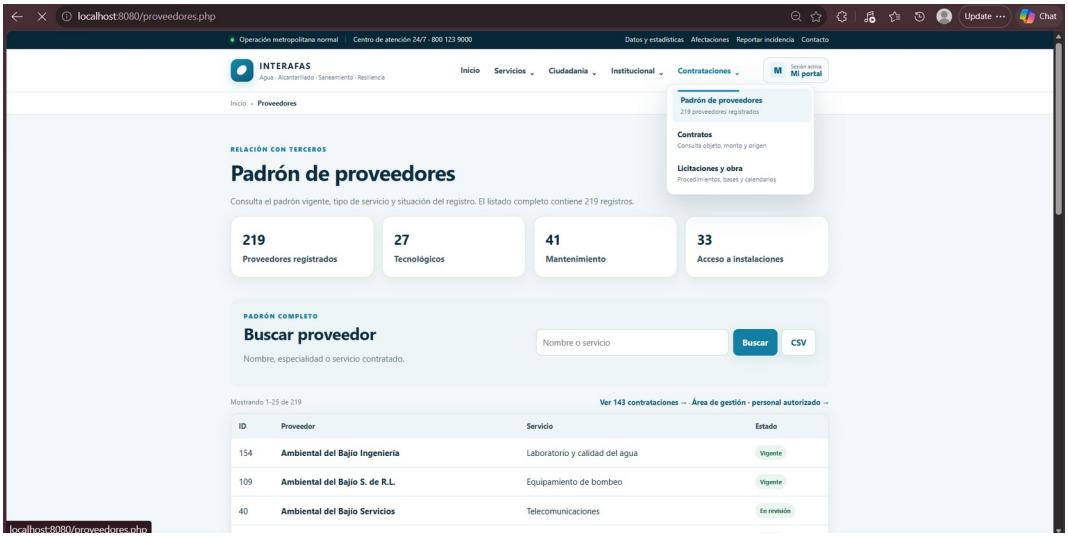
Descripción técnica y causa raíz

El archivo exportar.php implementa una estructura de control match en PHP para procesar el parámetro tipo de la URL. Al carecer de un caso default, el suministro de un valor no contemplado desencadena una excepción de tipo UnhandledMatchError. El entorno de producción tiene el modo de depuración activado (DEBUG RESPONSE ENABLED), lo que provoca la exposición de un rastreo de errores detallado (stack trace) que revela rutas de archivos, versiones de módulos, base de datos y un token de validación (la bandera).

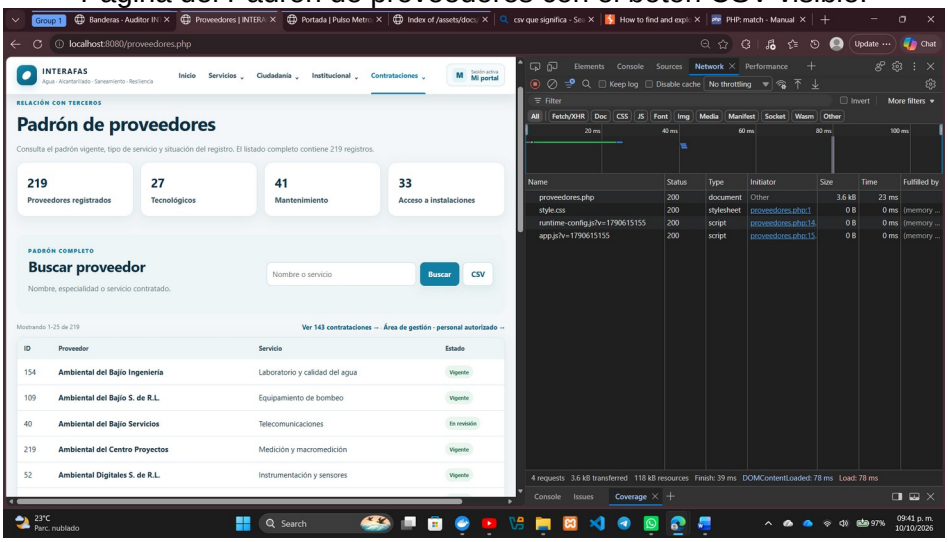
Comprobación de los hallazgos

1. Navegación al Padrón de proveedores e interceptación de la solicitud de exportación CSV (GET /exportar.php?tipo=proveedores).
2. Modificación manual del parámetro tipo por una entrada inválida (ej: tipo=morado).
3. Análisis de la página de error resultante.
4. Extracción de la bandera desde la tabla de diagnóstico de depuración.

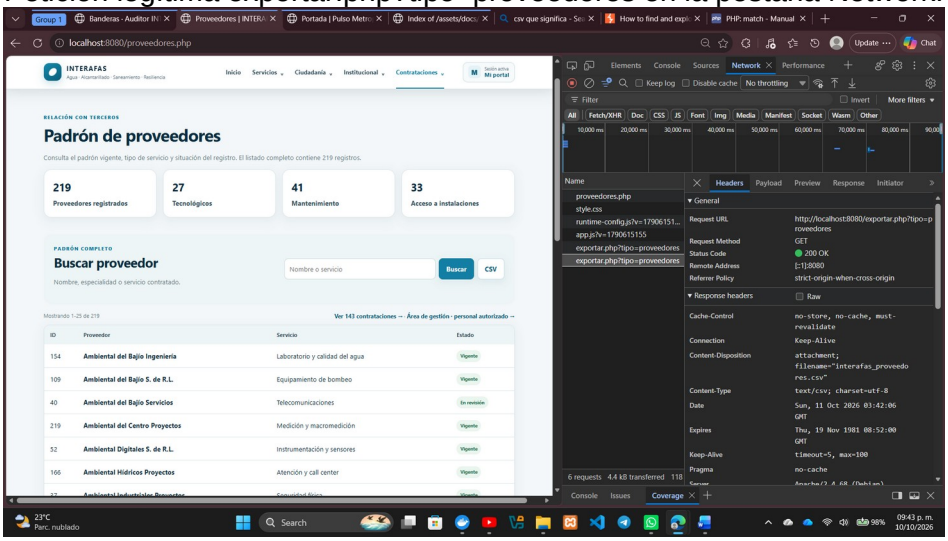
Evidencia técnica



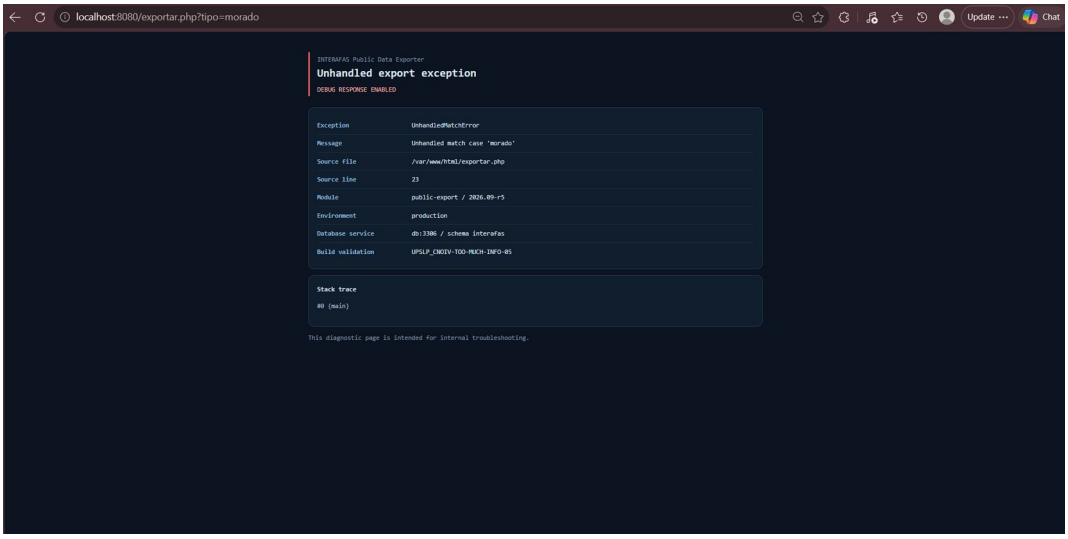
Página del Padrón de proveedores con el botón CSV visible.



Petición legítima exportar.php?tipo=proveedores en la pestaña Network.



URL modificada con valor inválido.



Página de error UnhandledMatchError mostrando la bandera UPSLP_CNOIV-TOO-MUCH-INFO-05.

Impacto y riesgo

Riesgo Medio. Filtra información técnica crítica del servidor (rutas absolutas, versiones y servicios de BD) que reduce el tiempo de la fase de reconocimiento de un atacante.

Mitigaciones

- Incluir un caso por defecto (default) en la expresión match que devuelva un mensaje de error genérico.
- Desactivar la visualización de errores detallados en producción configurando display_errors = Off en php.ini y enviar los errores a registros internos del servidor.
- Sanitizar y validar los parámetros de entrada antes de procesarlos.

Sexta Bandera

Escalamiento Vertical de Privilegios mediante Manipulación de Cookie de Rol

Identificador de la bandera: UPSLP_CNOIV-WRONG-ROLE-06

Componente afectado: Módulo de Gestión de Proveedores (gestion-proveedores.php)

Categoría: Broken Access Control / Privilege Escalation

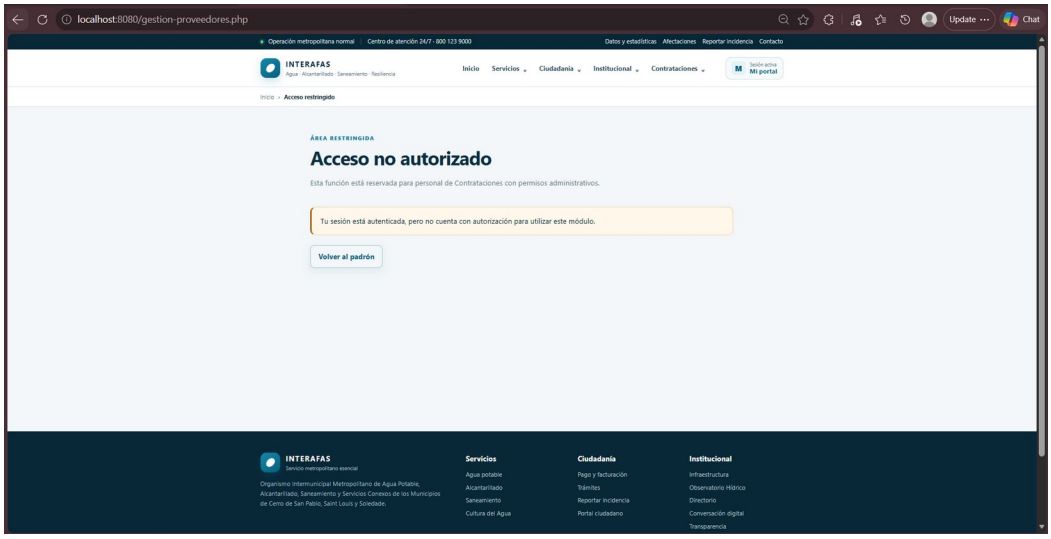
Descripción técnica y causa raíz

La aplicación confía ciegamente en el valor de la cookie portal_role (controlada desde el lado del cliente) para establecer los privilegios de la sesión. Un usuario logueado con el rol citizen puede evadir los controles de acceso simplemente modificando su cookie a procurement_admin. Al no verificar el rol real almacenado en la sesión del servidor, se concede acceso a módulos administrativos y se habilita la ejecución de operaciones privilegiadas, revelando la bandera tras ejecutar una acción de Marcar en revisión.

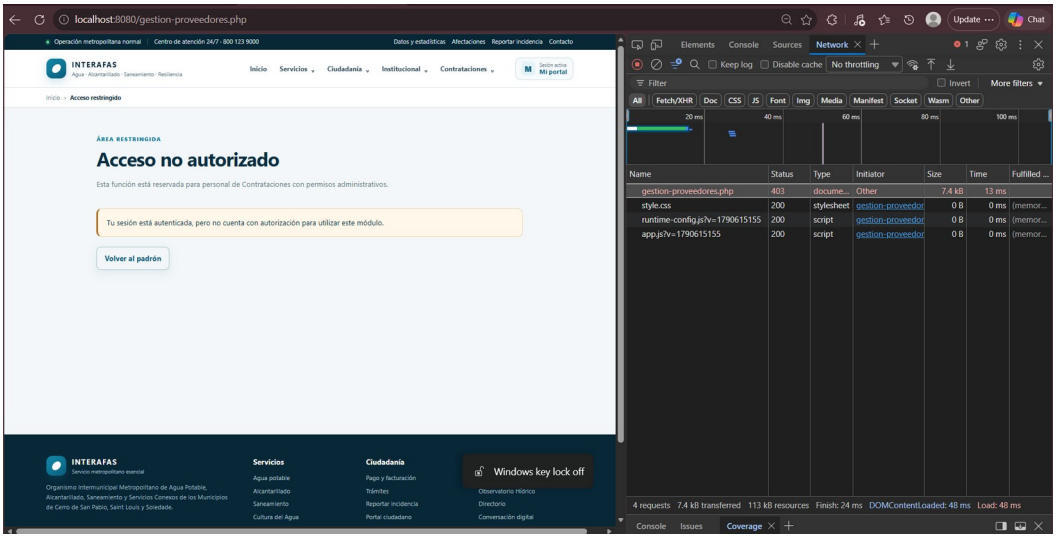
Comprobación de los hallazgos

1. Autenticación con una cuenta ciudadana.
2. Acceso a http://localhost:8080/gestion-proveedores.php, obteniendo la página de Acceso no autorizado.
3. Modificación del valor de la cookie portal_role=citizen a portal_role=procurement_admin usando las herramientas de desarrollador.
4. Recarga de la página, confirmando la elusión del control de acceso.
5. Ejecución de una acción administrativa (Marcar en revisión) sobre un proveedor, confirmando el escalamiento vertical y revelando la bandera.

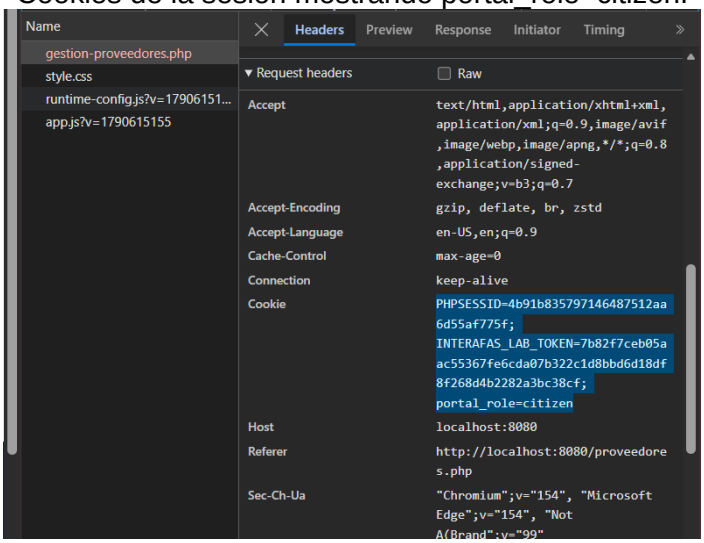
Evidencia técnica



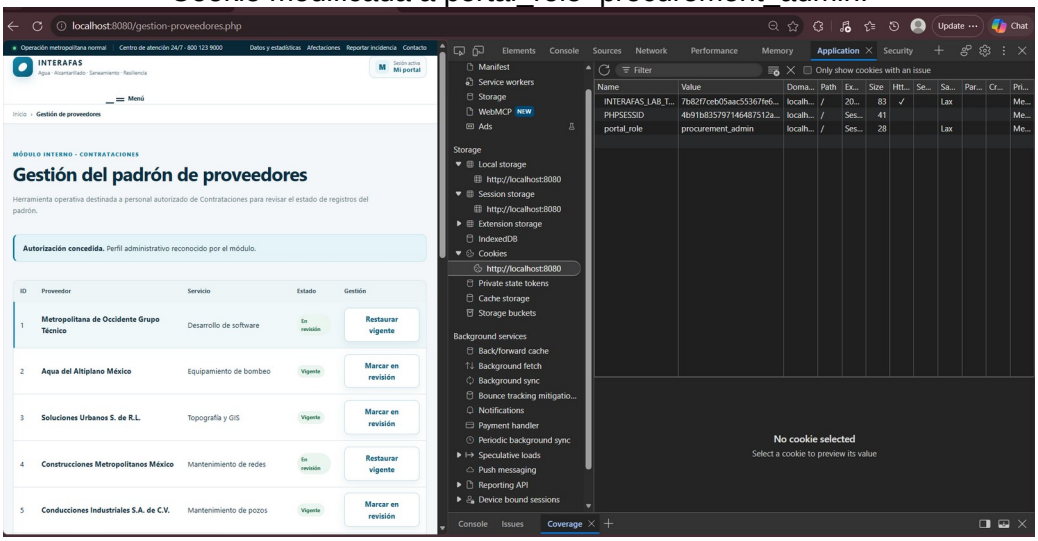
Mensaje de “Acceso no autorizado” con sesión ciudadana.



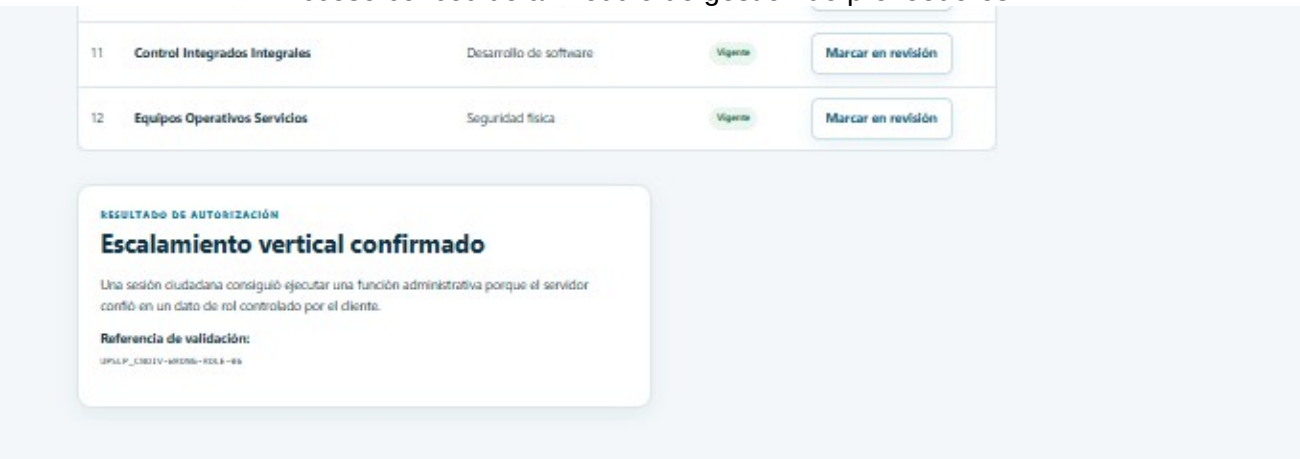
Cookies de la sesión mostrando portal_role=citizen.



Cookie modificada a portal_role=procurement_admin.



Acceso concedido al módulo de gestión de proveedores.



Acción administrativa ejecutada y bandera UPSLP_CNOIV-CLIENT-ROLE-06 visible.

Impacto y riesgo

Riesgo Crítico. Un atacante de bajo privilegio puede escalar permisos a nivel administrativo, comprometiendo por completo la integridad de las funciones operativas de la plataforma.

Mitigaciones

- Eliminar el uso de parámetros controlados por el cliente (cookies, headers, variables en URL) para decisiones de control de acceso.
- Manejar los roles exclusivamente del lado del servidor, recuperando el nivel de privilegios directamente de la sesión ($_SESSION['role']) validada en la base de datos.
- Aplicar verificaciones de autorización bajo el principio de denegación por defecto (Deny by Default) en todos los endpoints sensibles.

Séptima Bandera

Inyección SQL Ciega (Boolean-based Blind SQL Injection)

Identificador de la bandera: UPSLP_CNOIV-SILENT-ANSWER-07

Componente afectado: Módulo de Validación de Referencias (validar-referencia.php)

Categoría: SQL Injection (Blind / Boolean-based)

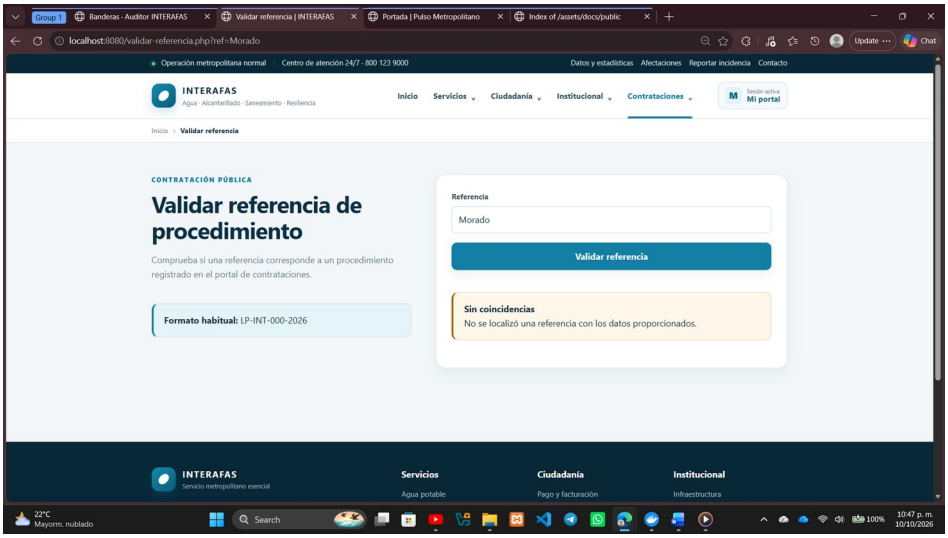
Descripción técnica y causa raíz

El parámetro ref es concatenado de manera directa en la consulta SQL del backend sin sanitización previa ni el uso de sentencias preparadas. Las variaciones en la respuesta (Referencia localizada vs Sin coincidencias) al inyectar condiciones booleanas (verdadero/falso) permiten extraer la estructura de la base de datos carácter por carácter. Se explotó la vulnerabilidad para enumerar y descargar una tabla entera mediante inferencia, obteniendo la bandera de la columna verification_token de la tabla portal_validation_meta.

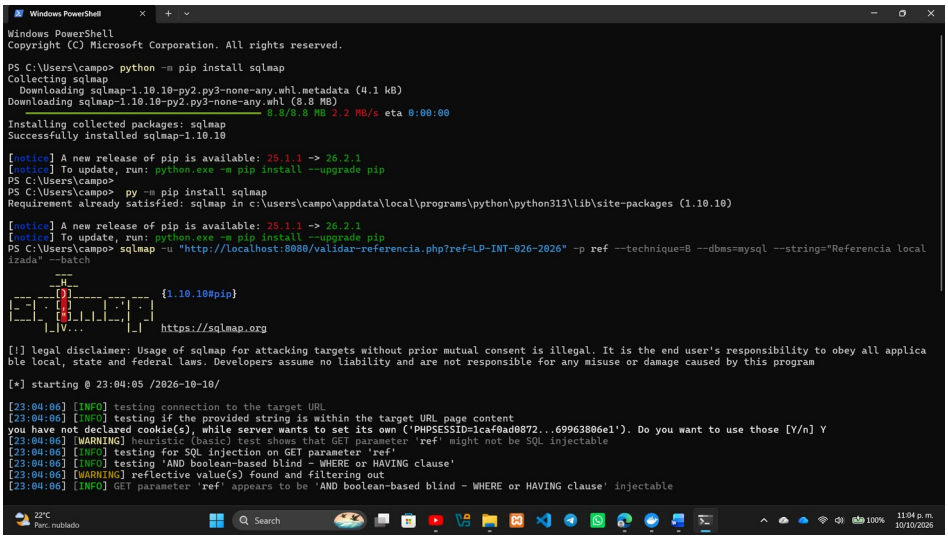
Comprobación de los hallazgos

1. Análisis del comportamiento del parámetro ref en http://localhost:8080/validar-referencia.php.
2. Ejecución de sqlmap definiendo la técnica booleana ciega (--technique=B) y proporcionando la cadena verdadera (--string="Referencia localizada").
3. Enumeración de bases de datos, localizando la base interafas.
4. Volcado de tablas en interafas, detectando portal_validation_meta.
5. Extracción del contenido de la columna verification_token, revelando la bandera.

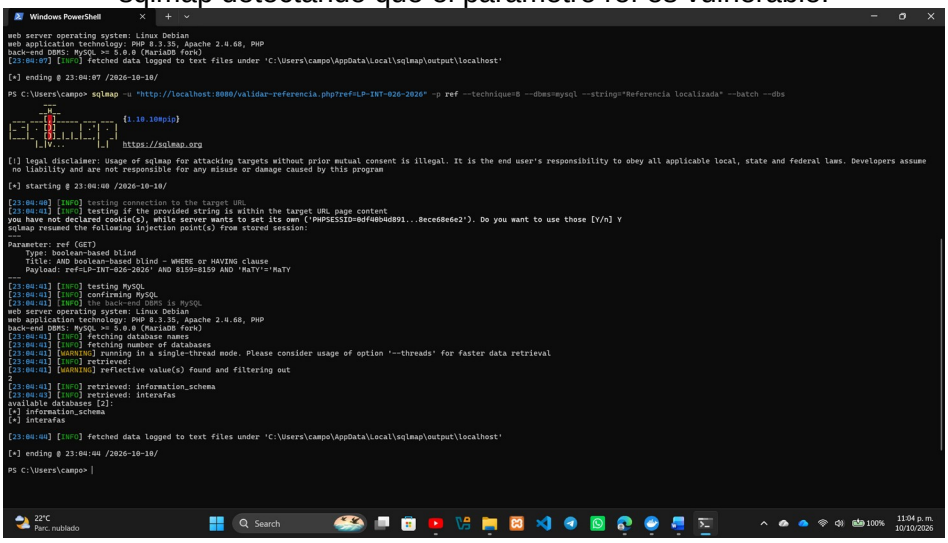
Evidencia técnica



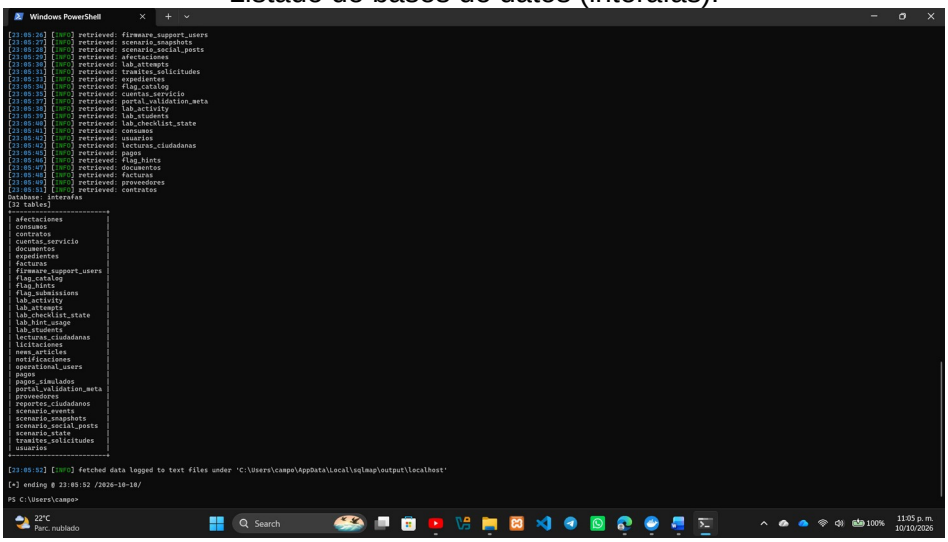
Página de validación de referencia (respuesta “Referencia localizada” y “Sin coincidencias”).



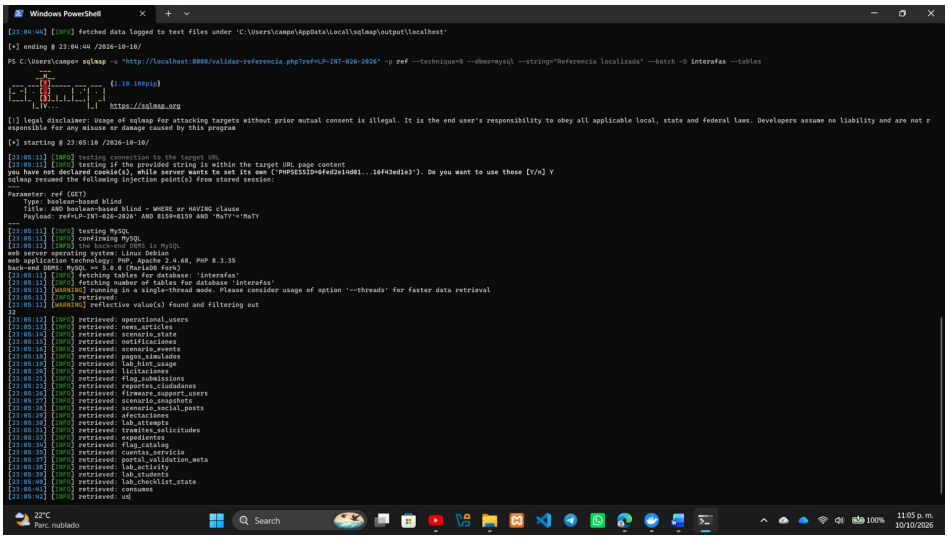
sqlmap detectando que el parámetro ref es vulnerable.



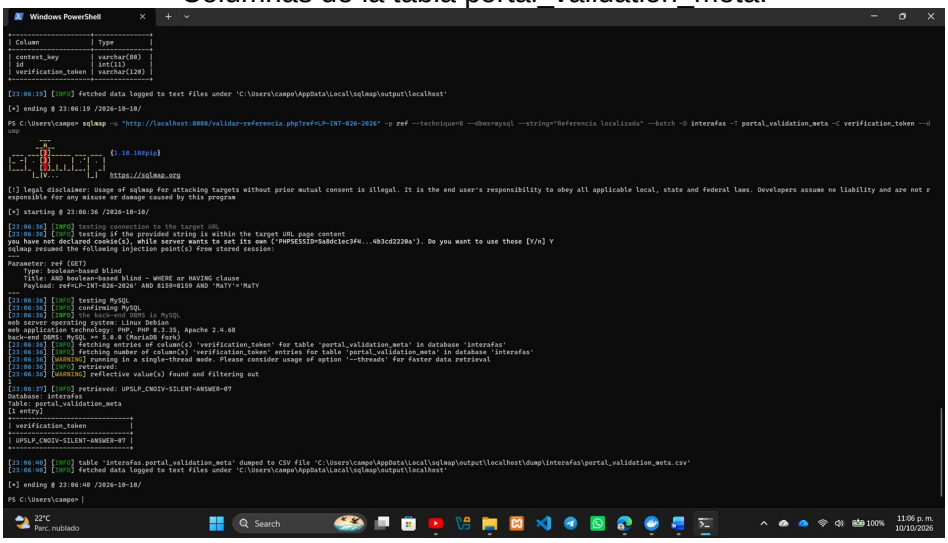
Listado de bases de datos (interafas).



Listado de tablas de la base interafas.



Columnas de la tabla portal_validation_meta.



Dump de la columna verification_token con la bandera UPSLP_CNOIV-SILENT-ANSWER-07.

Impacto y riesgo

Riesgo Crítico. Compromete en su totalidad la base de datos. Un atacante puede extraer datos confidenciales sin requerir mensajes de error, logrando el compromiso de credenciales y registros del sistema.

Mitigaciones

- Refactorizar el código para usar exclusivamente Consultas Preparadas (Prepared Statements / Parameterized Queries) mediante PDO o MySQLi.
- Sanitizar fuertemente las entradas con validación de tipo.
- Aplicar el principio de privilegios mínimos a la cuenta del usuario de la base de datos utilizada por la aplicación web.

Octava Bandera

Cross-Site Scripting (XSS) Almacenado mediante inyección en Reportes Ciudadanos

Identificador de la bandera: UPSLP_CNOIV-STORED-WORDS-08

Componente afectado: Módulo de Reportes Ciudadanos (reportes.php y seguimiento-reporte.php)

Categoría: Stored Cross-Site Scripting (XSS) / Inyección de código

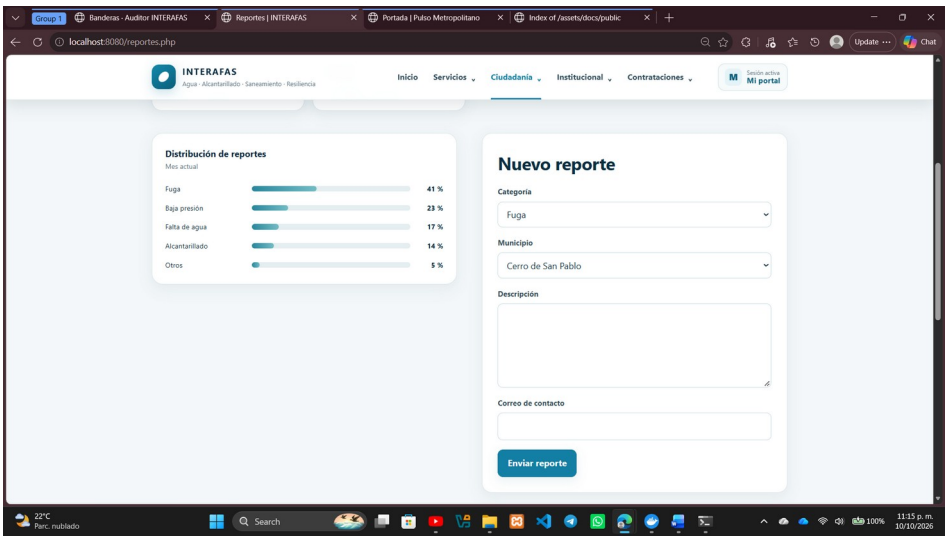
Descripción técnica y causa raíz

El módulo de reporte almacena datos suministrados por el usuario en el campo Descripción sin ningún proceso de sanitización. Posteriormente, la vista seguimiento-reporte.php procesa e imprime este contenido en el DOM HTML sin codificación de salida (Output Encoding). Esto permite la ejecución de código JavaScript arbitrario en el navegador de cualquier usuario (incluidos administradores) que visualice dicho reporte. Se identificó además una etiqueta meta oculta con un endpoint de validación que facilitó la extracción de la bandera mediante una petición fetch().

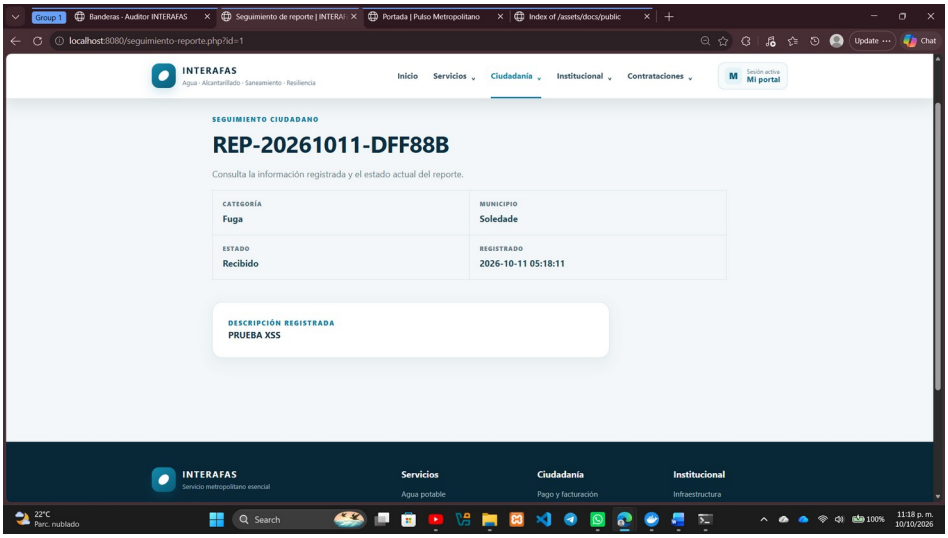
Comprobación de los hallazgos

1. Creación de un reporte inyectando una carga útil XSS en el campo Descripción en reportes.php.
2. Verificación de la inyección en la vista seguimiento-reporte.php?id=1.
3. Inspección del HTML identificando la etiqueta oculta <meta name="interafas-validation-endpoint">.
4. Simulación del ataque XSS desde la consola del navegador ejecutando una petición fetch().
5. Obtención y extracción del token desde la respuesta de la petición asíncrona.

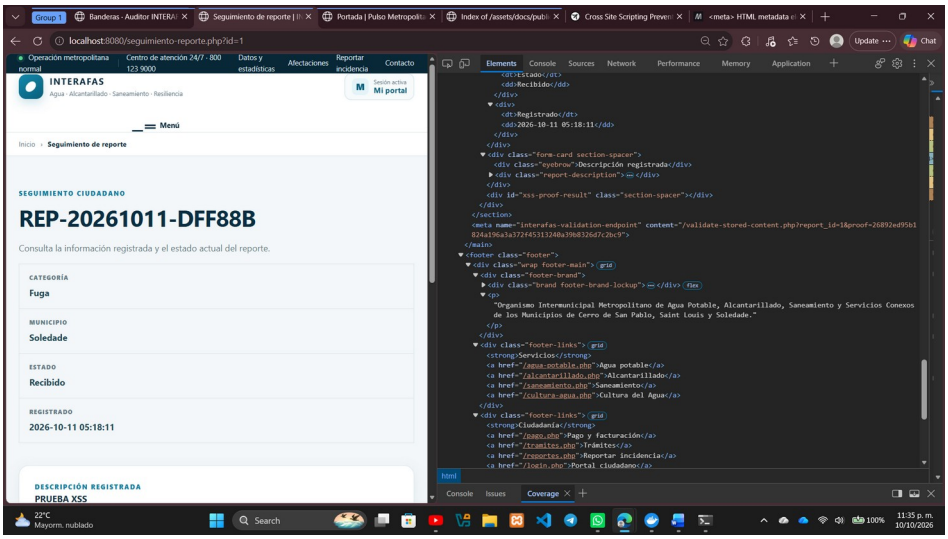
Evidencia técnica



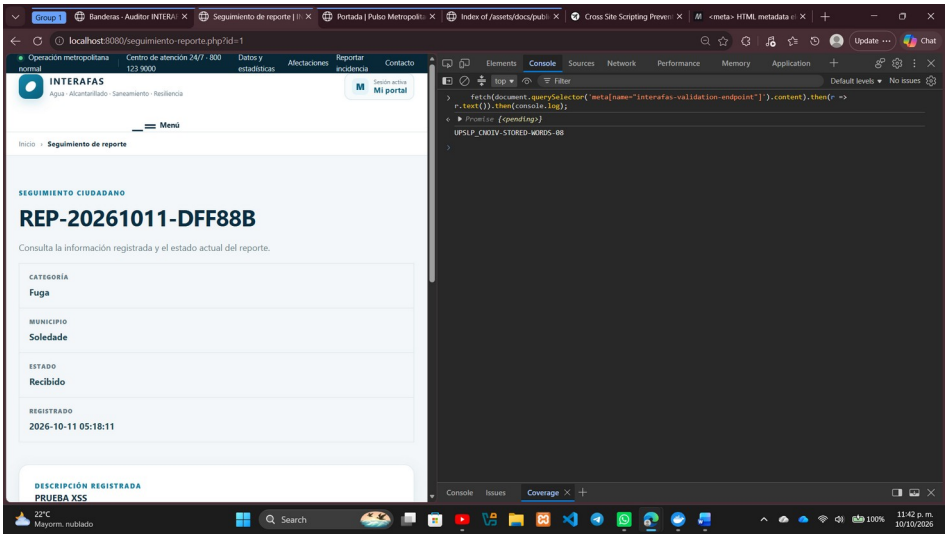
Formulario de creación de reporte con inyección XSS en el campo Descripción.



Visualización del reporte en seguimiento-reporte.php ejecutando el código inyectado.



Inspección del HTML revelando la etiqueta meta oculta con el endpoint de validación.



Ejecución de fetch() desde la consola y obtención de la bandera.

Impacto y riesgo

Riesgo Alto. Permite comprometer las sesiones de usuarios legítimos, facilitando el robo de cookies (Session Hijacking) y la ejecución de acciones administrativas automatizadas cuando personal de soporte revisa los reportes afectados.

Mitigaciones

- Implementar estricta codificación de salida (Output Encoding), transformando caracteres especiales en entidades HTML (ej. usar htmlspecialchars() en PHP).
- Aplicar reglas robustas de sanitización de entradas.
- Configurar cabeceras de Content Security Policy (CSP) para prevenir la ejecución de scripts en línea no autorizados.

Novena Bandera

Salto de Directorio (Path Traversal) / Inclusión de Archivos Locales (LFI)

Identificador de la bandera: UPSLP_CNOIV-TOO-DEEP-09

Componente afectado: Módulo de Documentos (descargar-documento.php)

Categoría: Path Traversal / Local File Inclusion (LFI)

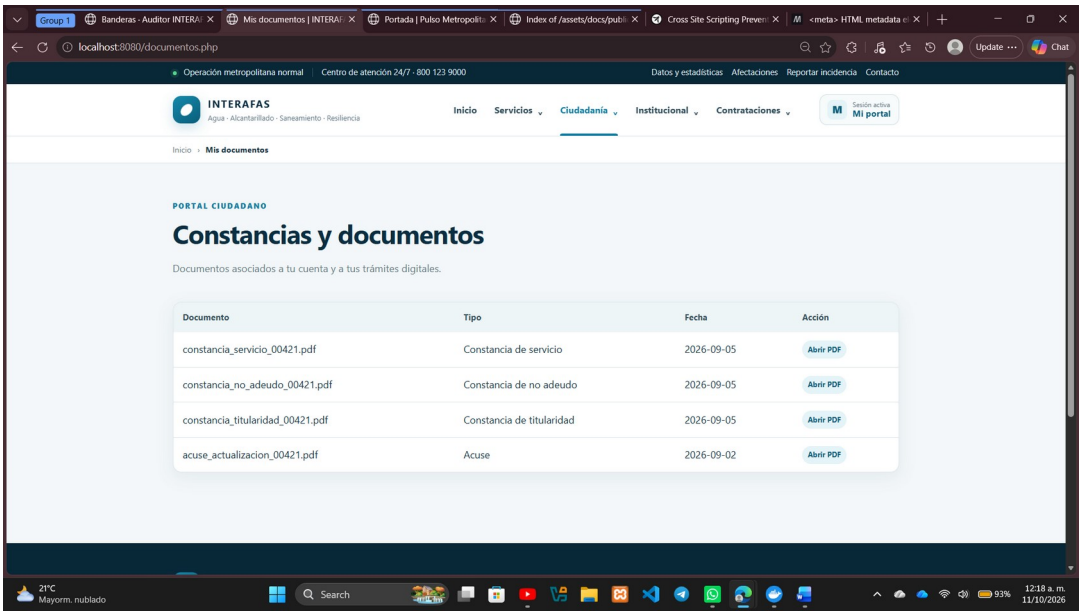
Descripción técnica y causa raíz

El script descargar-documento.php procesa el nombre de archivo a descargar a través del parámetro GET file. El backend carece de una validación adecuada y no implementa una estructura para delimitar (enjaular) el acceso al directorio base. Esto permite el procesamiento de caracteres de salto de directorio (../), permitiendo salir de la ruta de la aplicación web y realizar lecturas no autorizadas sobre archivos del sistema operativo host. Se logró leer /etc/motd, el cual contenía la bandera.

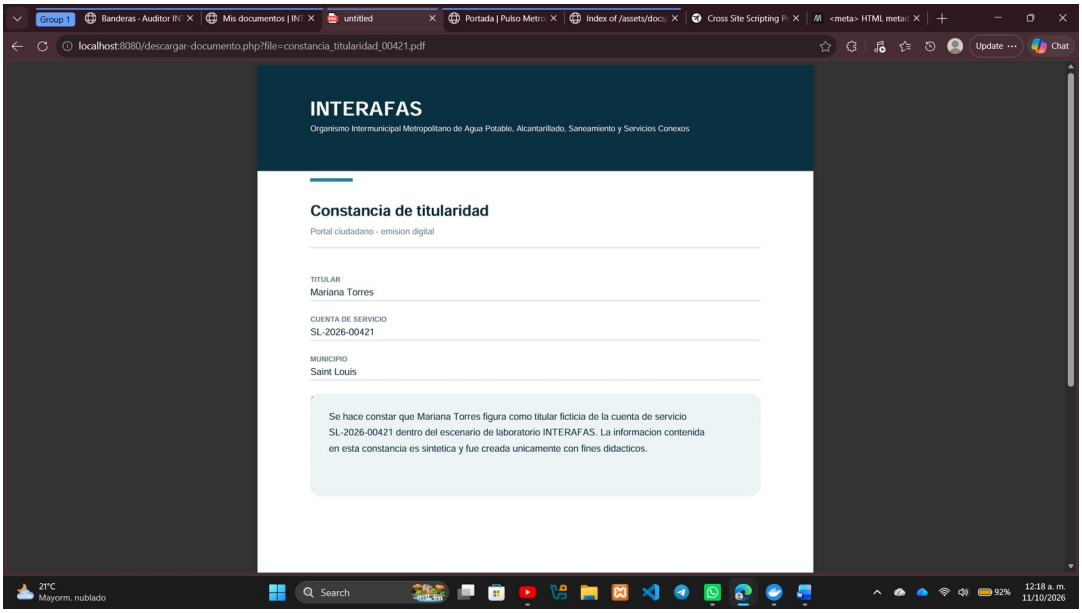
Comprobación de los hallazgos

1. Intercepción de un enlace de descarga legítimo (ej: descargar-documento.php?file=constancia...).
2. Manipulación de la URL inyectando una carga útil de Path Traversal: ../../../../../../etc/motd.
3. El servidor devolvió en texto plano el contenido de /etc/motd, el cual contenía la bandera.

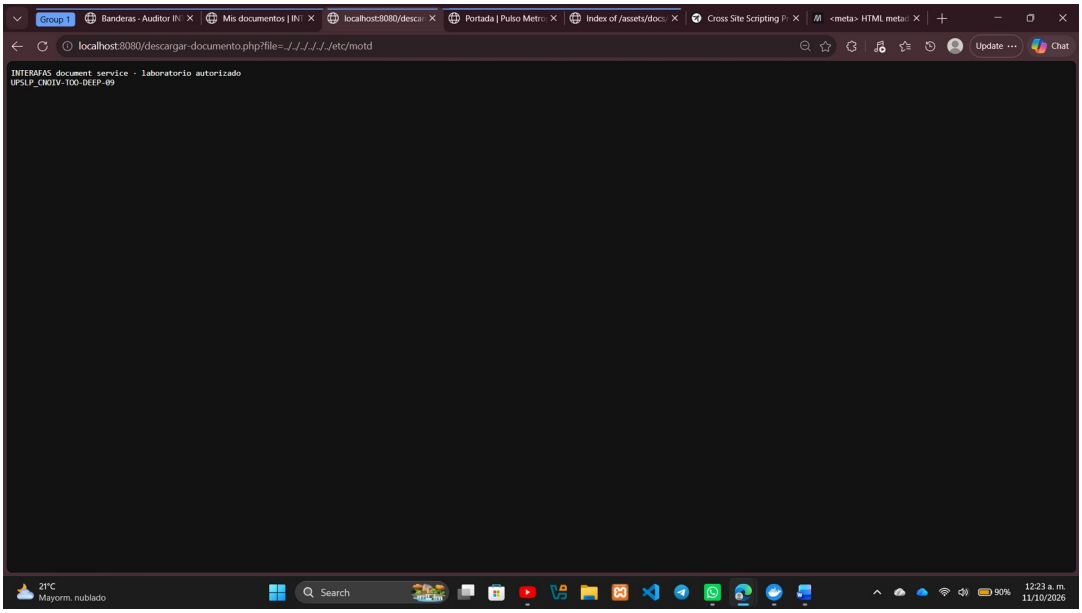
Evidencia técnica



Enlace de descarga legítimo interceptado.



Manipulación del parámetro file con carga útil de Path Traversal (../../../../../../etc/motd).



Respuesta del servidor devolviendo el contenido de /etc/motd con la bandera.

Impacto y riesgo

Riesgo Crítico. Compromete severamente la confidencialidad del servidor subyacente. Permite la lectura de archivos confidenciales (claves SSH, /etc/passwd, configuraciones .env), lo cual es un vector clásico para lograr Ejecución de Código Remoto (RCE).

Mitigaciones

- Implementar Mapeo Indirecto de Objetos (ej: usar ?id=5 en lugar del nombre del archivo en la URL) y recuperarlo de una base de datos.
- Sanitizar la variable eliminando caracteres de salto (../, ..\).
- Validar rigurosamente que el resultado de funciones como realpath() se mantenga estrictamente dentro de la ruta (Directorio Base) permitida de descargas antes de procesar el archivo.

Decima Bandera

Secuestro / Reutilización de Sesión (Session Replay) por falta de invalidación

Identificador de la bandera: UPSLP_CNOIV-WHO-ARE-YOU-10

Componente afectado: Autenticación / Gestión de Sesiones (perfil.php)

Categoría: Broken Authentication / Session Management Flaw (Replay Attack)

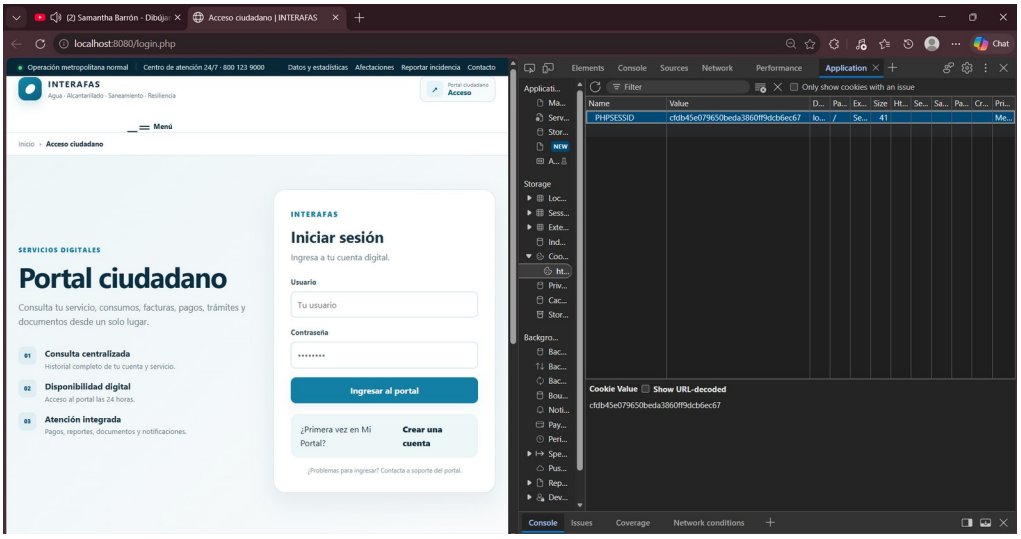
Descripción técnica y causa raíz

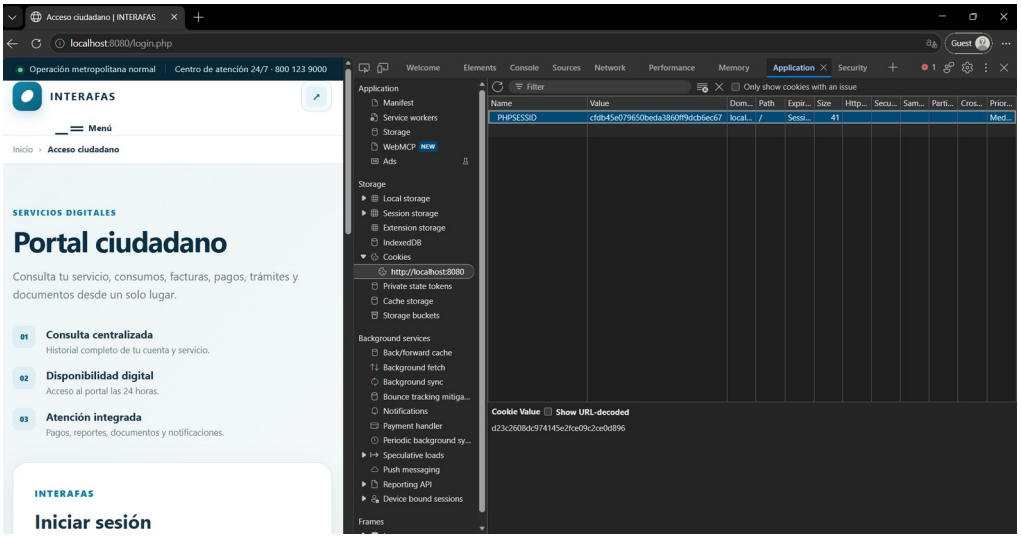
El servidor acepta identificadores de sesión antiguos o capturados que no fueron correctamente invalidados tras su uso. Al no implementar mecanismos estrictos de expiración o rotación de identificadores de sesión, un atacante puede inyectar una cookie capturada directamente en el almacenamiento de su navegador y obtener acceso legítimo a recursos protegidos sin necesidad de credenciales. La cabecera X-INTERAFAS-Session-State: replay-accepted confirma la aceptación de la sesión reutilizada.

Comprobación de los hallazgos

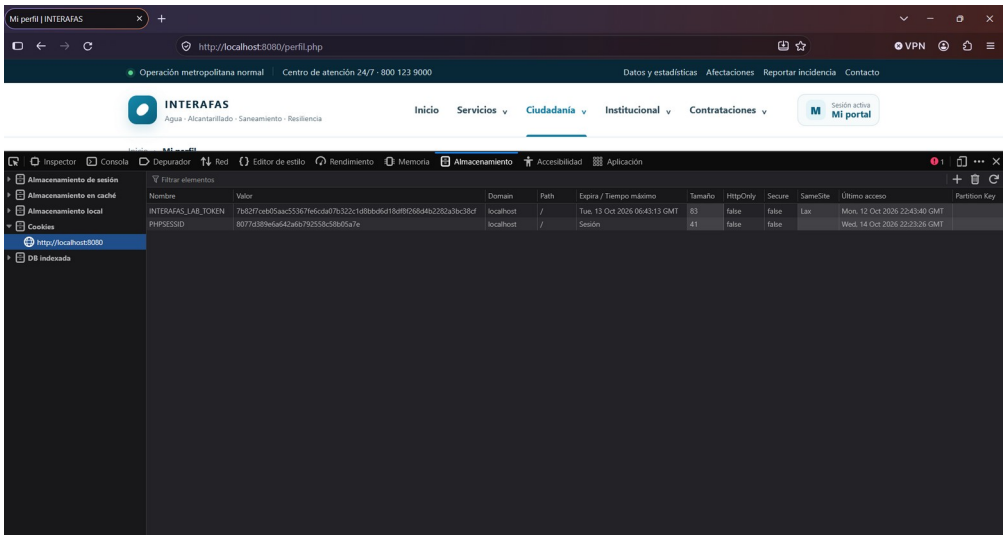
1. Obtención de un identificador de sesión previamente válido.
2. Apertura de las herramientas de desarrollador (DevTools) en la pestaña Almacenamiento.
3. Inyección manual de la cookie de sesión.
4. Navegación hacia el endpoint restringido http://localhost:8080/perfil.php.
5. Inspección del tráfico en la pestaña de Red, donde se observa que el servidor aceptó la sesión (X-INTERAFAS-Session-State: replay-accepted), revelando la bandera.

Evidencia técnica

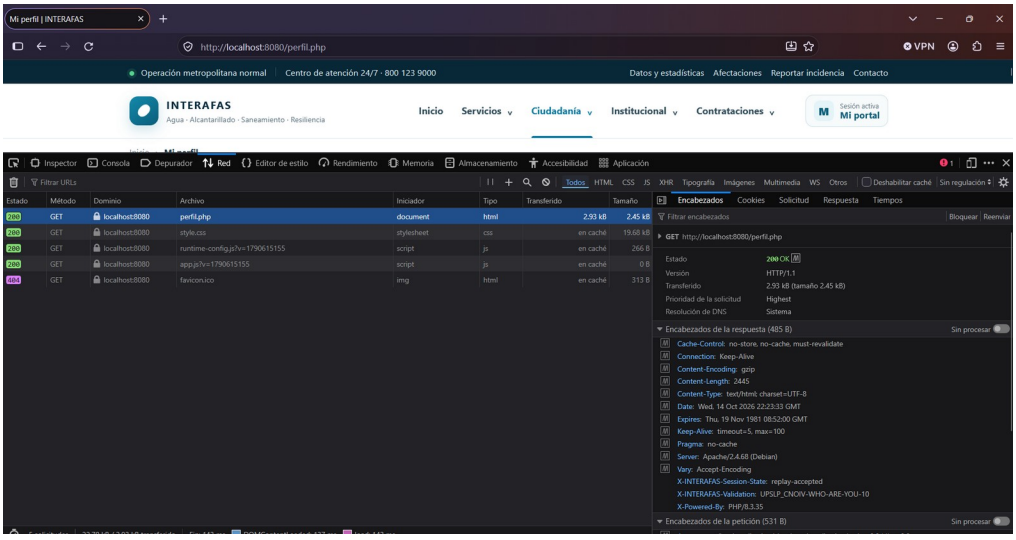




Obtención e inyección de una cookie de sesión previamente válida.



Acceso exitoso a perfil.php con la sesión reutilizada.



Cabecera X-INTERAFAS-Session-State: replay-accepted confirmando la aceptación del replay.

Impacto y riesgo

Riesgo Alto. Compromete severamente la confidencialidad e integridad de las cuentas. Si un atacante logra interceptar una cookie, puede impersonar a cualquier ciudadano o administrador y realizar acciones en su nombre.

Mitigaciones

- Implementar la función de regeneración del identificador de sesión inmediatamente después de cualquier autenticación exitosa.
- Forzar tiempos de expiración absolutos y por inactividad cortos para todas las cookies de sesión.
- Destruir explícita y completamente la sesión en el servidor al momento del cierre de sesión.

Undécima Bandera

Exposición de Endpoint Oculto y Fuga de Información (Historial de Servicios)

Identificador de la bandera: UPSLP_CNOIV-HIDDEN-HISTORY-11

Componente afectado: API de Historial de Servicios (/api/service-history.php)

Categoría: Information Disclosure / Endpoint no documentado

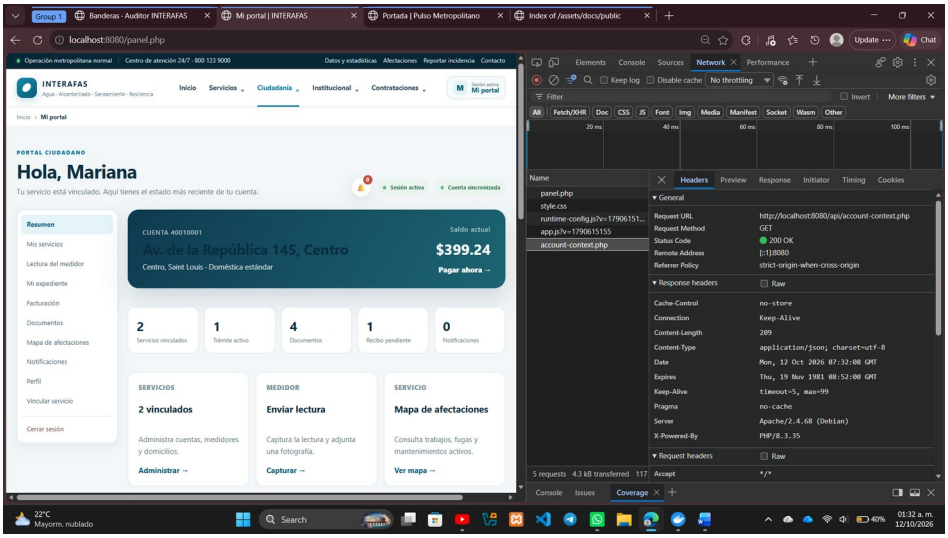
Descripción técnica y causa raíz

Al inspeccionar el tráfico de red de la aplicación, se detectó que el script account-context.php devuelve un objeto JSON que expone rutas de la API interna, como el nodo links.history que apunta a /api/service-history.php?account=40010001. El servidor falla al ofuscar estos endpoints y expone cabeceras de depuración en producción. Al acceder a la URL, la respuesta entrega el historial completo y en sus cabeceras HTTP (X-Interafas-Validation) se localiza la bandera.

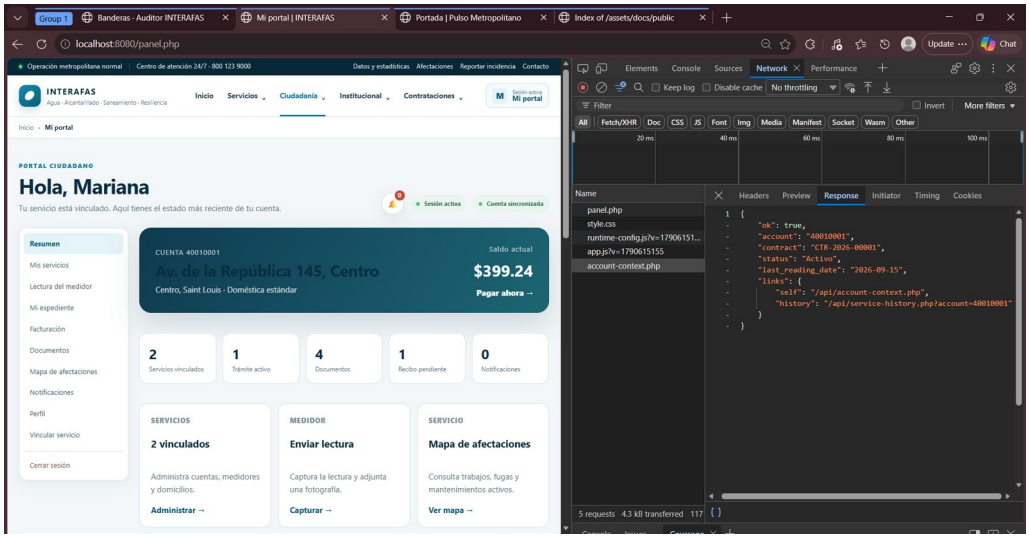
Comprobación de los hallazgos

1. Uso de la pestaña Network en el panel principal (panel.php).
2. Inspección de la respuesta de account-context.php y descubrimiento del endpoint service-history.php.
3. Acceso directo a la URL descubierta.
4. Análisis de los Response Headers y extracción de la bandera UPSLP_CNOIV-HIDDEN-HISTORY-11.

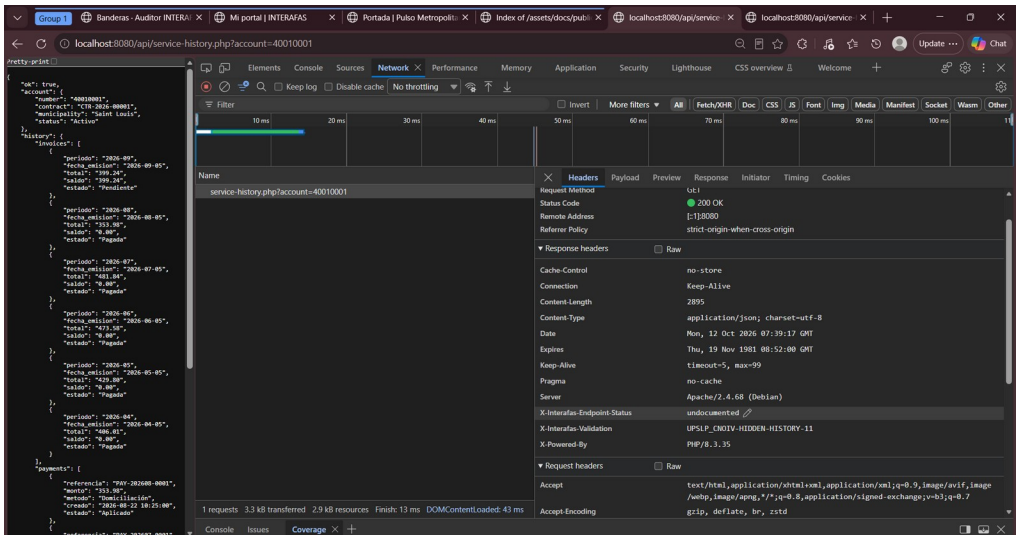
Evidencia técnica



Petición a account-context.php en la pestaña Network.



Respuesta JSON exponiendo el enlace al endpoint /api/service-history.php.



Acceso directo al endpoint y extracción de la bandera desde los Response Headers (X-Interafas-Validation).

Impacto y riesgo

Riesgo Medio. Facilita el mapeo de la superficie de ataque y expone las rutas internas para preparar ataques de manipulación de identificadores (IDOR) y revela lógica del sistema mediante las cabeceras personalizadas.

Mitigaciones

- Eliminar las rutas no esenciales en las respuestas de la API pública.
- Configurar el servidor web de producción para inhibir el envío de cabeceras de desarrollo/depuración (X-Interafas-*).

Duodécima Bandera

Referencia Directa Insegura a Objetos (IDOR) en API de Historial

Identificador de la bandera: UPSLP_CNOIV-SECOND-ACCOUNT-12

Componente afectado: API de Historial de Servicios (/api/service-history.php)

Categoría: Insecure Direct Object Reference (IDOR) / Broken Object Level Authorization (BOLA)

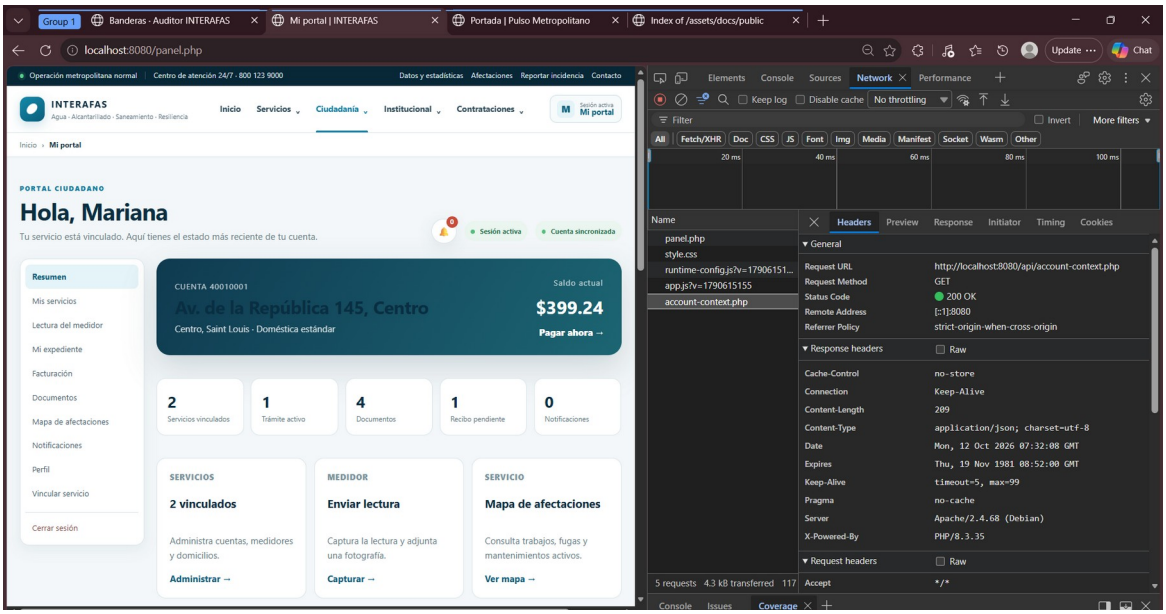
Descripción técnica y causa raíz

El endpoint /api/service-history.php evalúa el número de cuenta (account) directamente desde la URL mediante una solicitud GET. La API carece de controles a nivel de objeto (BOLA) y no cruza el parámetro con la identidad del solicitante. Un usuario autenticado puede extraer datos de cuentas a las que no tiene permiso modificando dicho parámetro. La bandera se recibe como parte de las cabeceras de la respuesta.

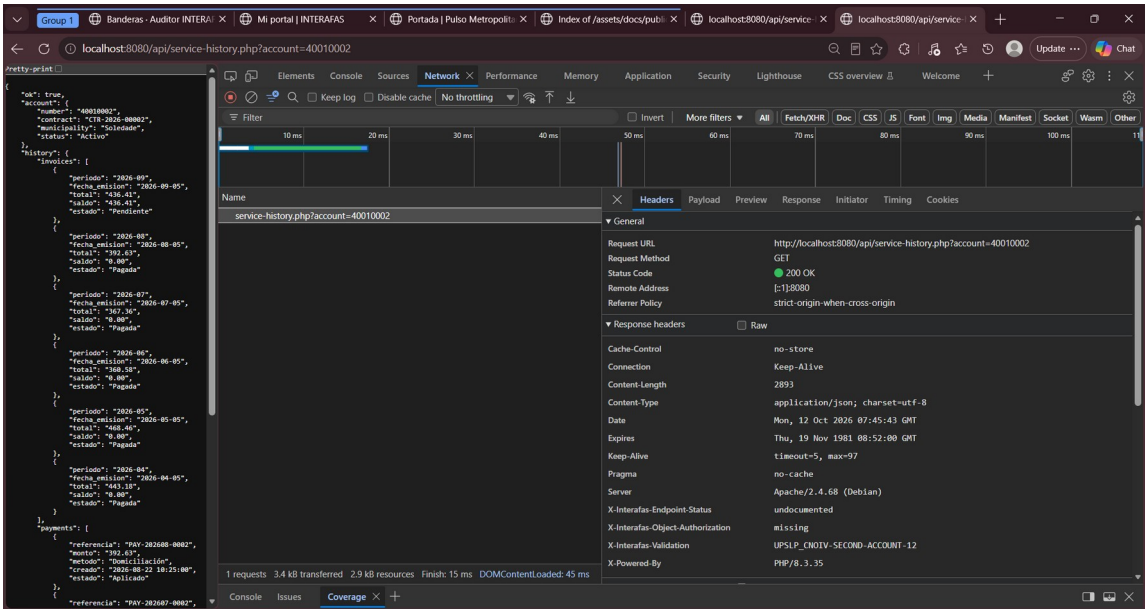
Comprobación de los hallazgos

1. Re-envío de la petición al endpoint /api/service-history.php alterando el valor original 40010001 por 40010002.
2. El servidor devuelve un código de estado 200 OK junto con el historial completo de la cuenta 40010002.
3. Extracción de la bandera desde las cabeceras de la respuesta.

Evidencia técnica



Petición original a /api/service-history.php?account=40010001.



Cabeceras de respuesta conteniendo la bandera.

Impacto y riesgo

Riesgo Crítico. Compromete totalmente la privacidad financiera, ya que cualquier usuario logueado puede enumerar y exfiltrar todo el historial de transacciones, saldos y pagos del universo de ciudadanos.

Mitigaciones

• Exigir controles rigurosos de Autorización de Nivel de Objeto (BOLA). Validar programáticamente que el valor de account solicitado está registrado a nombre del user_id asociado a la sesión y declinar la operación con un error de autorización en caso contrario.

Decimotercera Bandera

Manipulación de Parámetros en Pasarela de Pago (Business Logic Flaw)

Identificador de la bandera: UPSLP_CNOIV-PAYMENT-PATH-13

Componente afectado: Módulo de Pagos y Facturación (pago.php)

Categoría: Parameter Tampering / Broken Access Control (Business Logic Vulnerability)

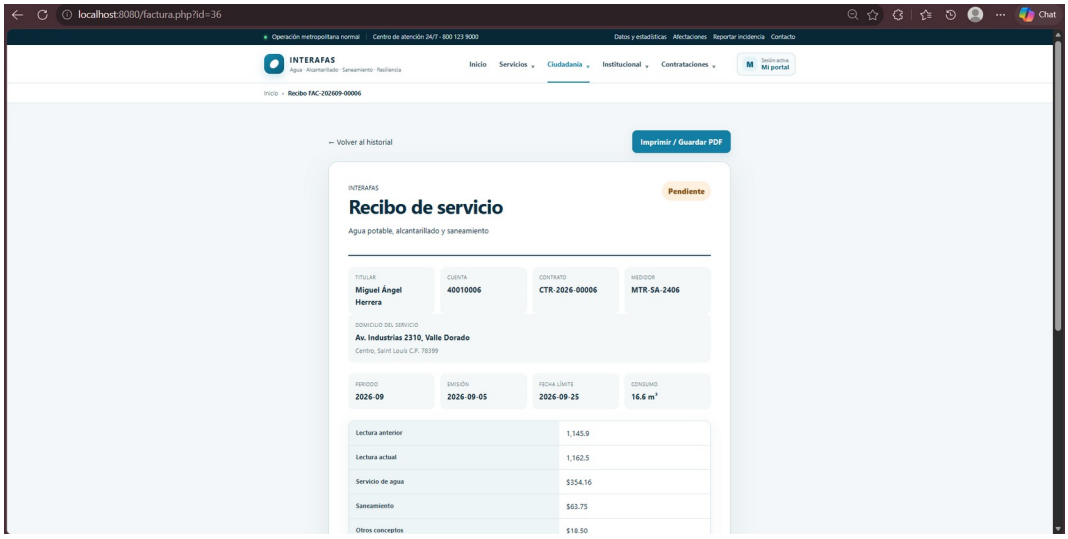
Descripción técnica y causa raíz

La lógica de negocio en el procesamiento de pagos presenta un error de validación. El backend confía ciegamente en el parámetro de costo (monto) enviado desde el formulario del cliente (vía POST) sin revalidarlo contra el valor real almacenado en la base de datos. Esto permite interceptar la solicitud y alterar el valor económico antes de que llegue al servidor, forzando al sistema a registrar como Pagada una factura liquidada por una fracción de su costo real.

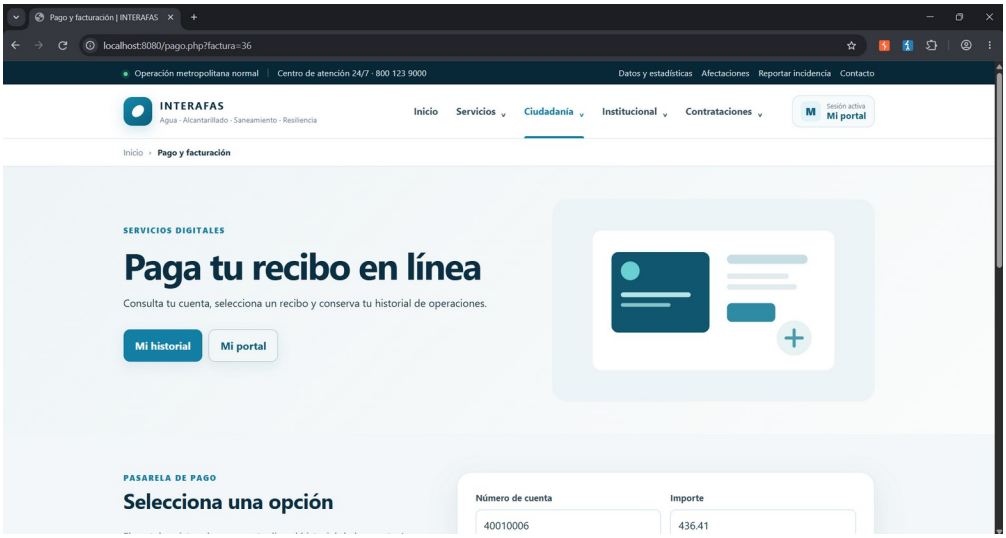
Comprobación de los hallazgos

1. Inicio de sesión y navegación al historial de facturación de la cuenta 40010006, localizando un recibo pendiente por $436.41.
2. Selección del botón para proceder a la pasarela de pago en línea.
3. Intercepción de la petición HTTP POST dirigida a pago.php?factura=36 utilizando un proxy web (Burp Suite).
4. Manipulación del parámetro original monto=436.41 por un importe arbitrario menor (ej. monto=85.47).
5. Envío de la petición alterada al servidor y revisión de la respuesta HTTP, donde el servidor confirma la transacción exponiendo las cabeceras de depuración y la bandera.

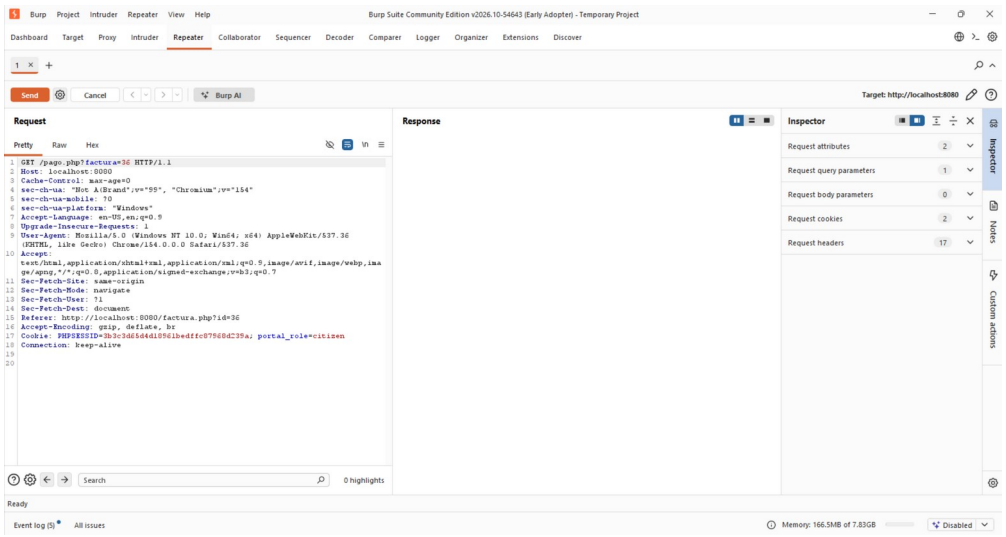
Evidencia técnica



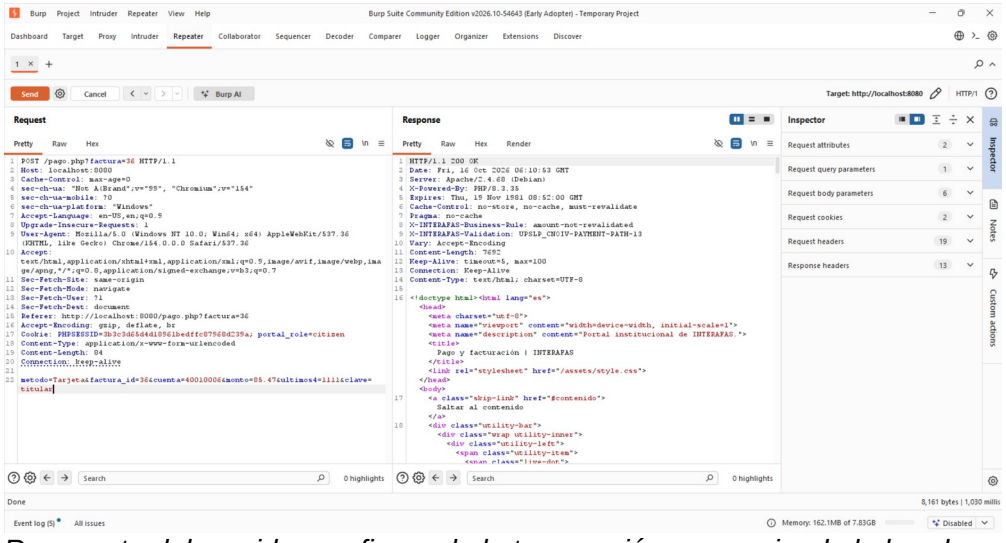
Historial de facturación mostrando recibo pendiente de $436.41.



Interceptación de la petición POST a pago.php con Burp Suite.



Manipulación del parámetro monto a un valor inferior.



Respuesta del servidor confirmando la transacción y exponiendo la bandera.

Impacto y riesgo

Riesgo Crítico. Impacto financiero directo. Permite a los usuarios evadir el pago completo de los servicios, causando pérdidas económicas cuantiosas a la organización.

Mitigaciones

- Nunca confiar en precios o montos enviados desde el entorno del cliente.
- El backend debe recibir únicamente el identificador del objeto, consultar en la base de datos el monto real adeudado y procesar el cobro exclusivamente con ese valor recuperado y validado en el servidor.

Decimocuarta Bandera

Referencia Directa Insegura a Objetos (IDOR) en Validación de Contratos

Identificador de la bandera: UPSLP_CNOIV-CONTRACT-LINK-14

Componente afectado: Módulo de Contrataciones – función pública Validar vínculo de un contrato

Categoría: Insecure Direct Object Reference (IDOR) / Broken Object Level Authorization

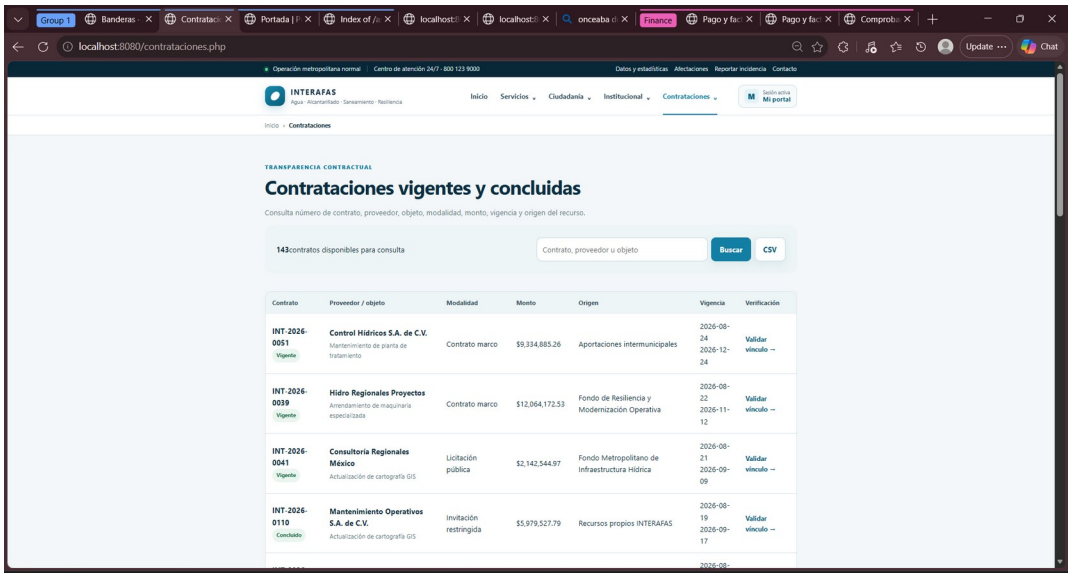
Descripción técnica y causa raíz

La función de validación de contratos expuesta de forma pública evalúa de forma independiente los identificadores de contrato (contract_id) y de proveedor (provider_id). La vulnerabilidad de control de autorización a nivel de objeto radica en que el sistema simplemente verifica si cada registro existe, pero omite validar si existe una relación autorizada (ownership) entre ellos. Esto permite validar combinaciones de proveedores y contratos completamente inconsistentes.

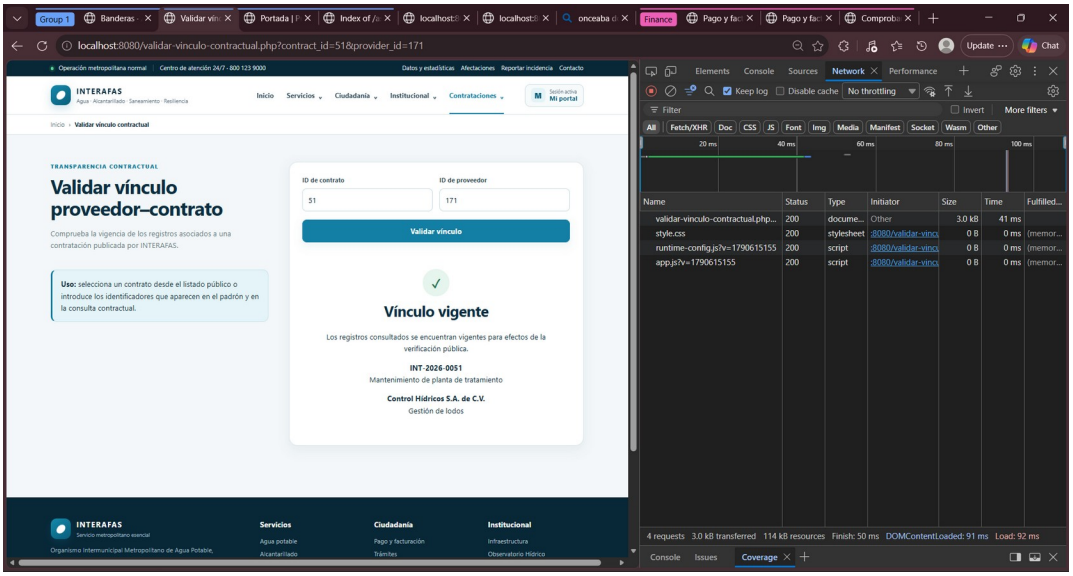
Comprobación de los hallazgos

1. Análisis de la función de validación registrando los identificadores legítimos.
2. Manipulación de la solicitud, sustituyendo únicamente el ID de proveedor por el de otro contratista ajeno.
3. Ejecución de la petición; el servicio valida el vínculo de manera errónea, demostrando la ausencia de comprobaciones relacionales.

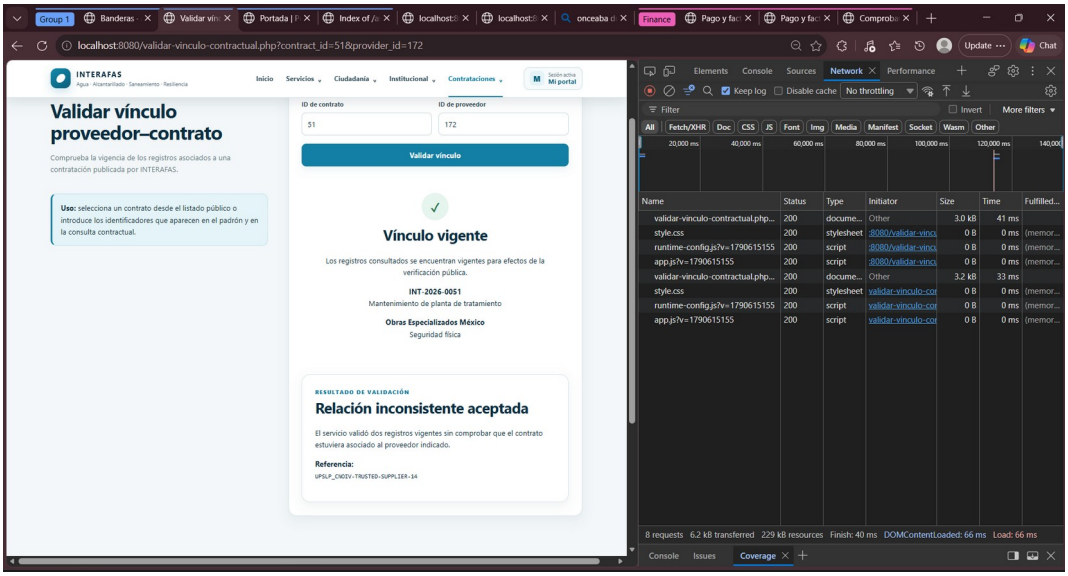
Evidencia técnica



Petición legítima de validación de vínculo contractual.



Manipulación del provider_id manteniendo el mismo contract_id.



Respuesta del servicio validando incorrectamente la relación inexistente.

Impacto y riesgo

Riesgo Crítico sobre la Confidencialidad. Permite enumerar y exponer vínculos contractuales y relaciones de negocios de terceros, lo que podría usarse para espionaje industrial, manipulación de contratos y fraudes.

Mitigaciones

- Implementar controles de Autorización basados en Relaciones (ReBAC). El sistema debe realizar un JOIN o verificación de integridad referencial en la base de datos para asegurar que el provider_id es, de hecho, el titular legítimo del contract_id consultado.

Decimoquinta Bandera

Exposición de Información Sensible y Telemetría Interna mediante Mapa de Infraestructura

Identificador de la bandera: UPSLP_CNOIV-INFRA-MAP-15

Componente afectado: Infraestructura estratégica / servicio de mapa genérico

Categoría: Information Disclosure / Sensitive Data Exposure

Descripción técnica y causa raíz

Al navegar en el portal público de infraestructura, se realizan llamadas hacia un servicio de mapa genérico que expone excesiva telemetría operativa. La respuesta contiene metadatos de depuración como segmentación de redes, historial de confianza, niveles de telemetría y direcciones CIDR de servicios que deberían permanecer en segmentos operativos internos. El servidor expone un diagnóstico activado en un entorno que debe ser opaco al público.

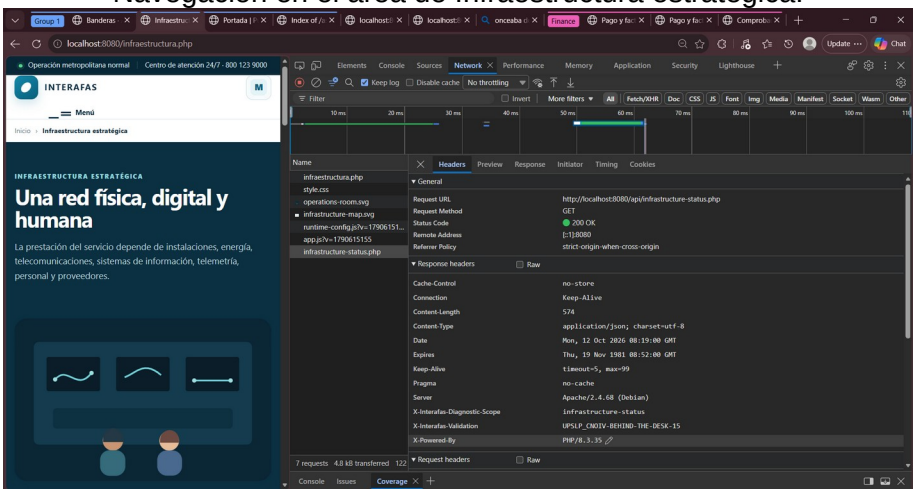
Comprobación de los hallazgos

1. Navegación en el área de Infraestructura estratégica.
2. Auditoría del tráfico usando DevTools en la pestaña de red.
3. Aislamiento y análisis completo del cuerpo de la respuesta JSON del servicio del mapa, identificando el indicador de diagnóstico interno.
4. Mapeo de la información filtrada, documentando segmentos operativos, subredes y variables del sistema interno.

Evidencia técnica



Navegación en el área de Infraestructura estratégica.



Cuerpo de la respuesta JSON con telemetría excesiva, segmentos de red y diagnóstico activado.

Impacto y riesgo

Riesgo Medio-Alto. Permite la reconstrucción del mapa de topología operativa del sistema, exponiendo la superficie de ataque interna. Un atacante ahorra horas de fase de descubrimiento utilizando datos entregados gratuitamente por la propia aplicación.

Mitigaciones

- Filtrar rigurosamente los datos antes de enviarlos al frontend, eliminando campos de diagnóstico y datos de telemetría detallada.
- Desacoplar los servicios de topología: separar estrictamente los endpoints que sirven vistas públicas frente a los que monitorean operaciones de telemetría (estos últimos deben requerir segmentación y VPN).

Decimosexta Bandera

Bypass de Gateway Restringido mediante Manipulación de Cabeceras de Origen (IP Spoofing / X-Forwarded-For)

Identificador de la bandera: UPSLP_CNOIV-GATEWAY-SPOOF-16

Componente afectado: Gateway restringido / segmento operativo (HTTP-001)

Categoría: Broken Access Control / IP Spoofing / Authorization Bypass

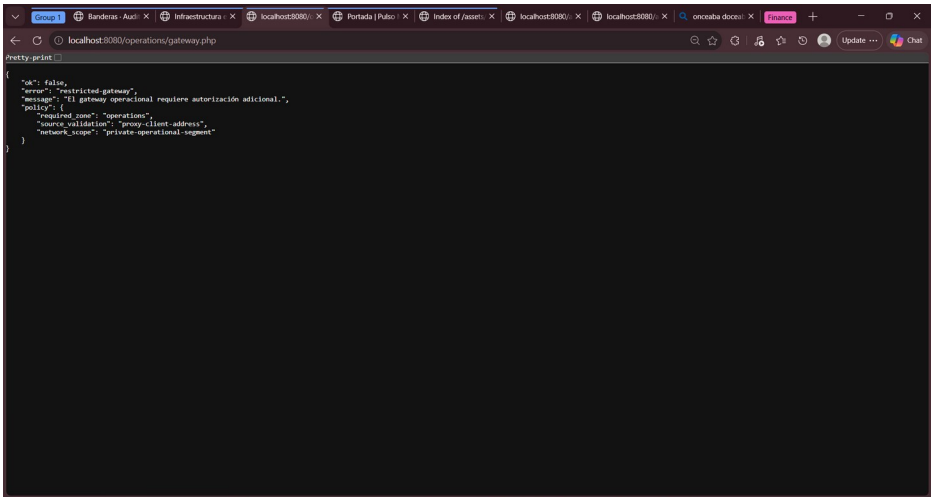
Descripción técnica y causa raíz

El Gateway del segmento operativo aplica reglas de control de acceso basándose en la dirección IP de origen. Sin embargo, la validación sufre de un grave error arquitectónico al depositar confianza en cabeceras de proxy HTTP controladas por el cliente (típicamente X-Forwarded-For) en lugar de en la capa de red (Socket IP). Un atacante externo puede suplantar direcciones de la subred autorizada (IP Spoofing) en sus peticiones para burlar las restricciones y obtener información restringida del segmento.

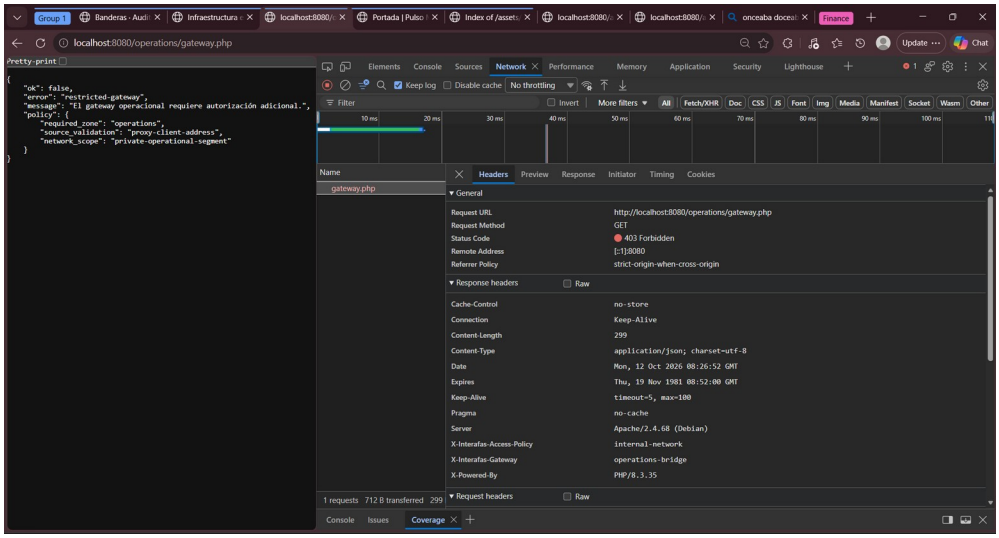
Comprobación de los hallazgos

1. Análisis de la respuesta HTTP 403 proporcionada por el Gateway de operaciones.
2. Modificación de la petición inyectando un encabezado de X-Forwarded-For suplantando un origen de red interno (segmento operativo).
3. Emisión de la solicitud, consiguiendo eludir la protección y logrando obtener información restringida del segmento.

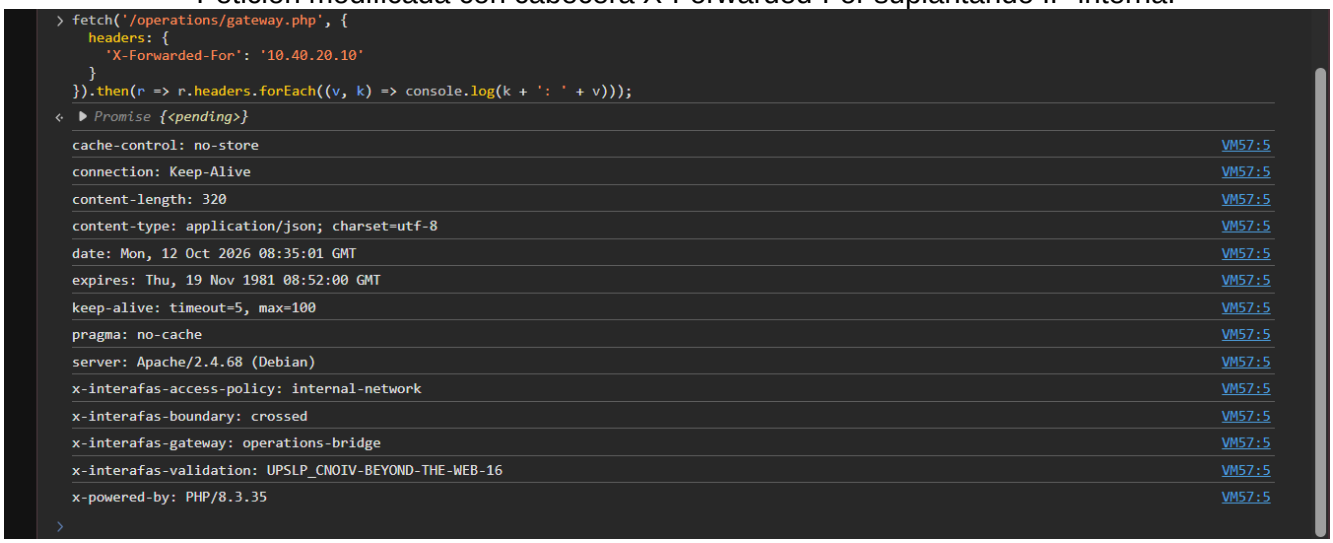
Evidencia técnica



Respuesta HTTP 403 del Gateway operativo.



Petición modificada con cabecera X-Forwarded-For suplantando IP interna.



Acceso exitoso a información restringida del segmento operativo.

Impacto y riesgo

Riesgo Crítico. Elusión total de controles de segmentación. Facilita el acceso de agentes externos hostiles a zonas de red clasificadas de operaciones críticas, comprometiendo todo el sistema perimetral.

Mitigaciones

- Prohibir validaciones de seguridad perimetral sustentadas en cabeceras HTTP suministradas por clientes.
- Evaluar el acceso utilizando la dirección IP de origen real a nivel del protocolo de red (TCP/IP).
- Implementar autenticaciones de red seguras (como validación de certificados TLS mutuo – mTLS) y mecanismos de autorización adicionales más allá del control de capa de red.

Decimoseptima Bandera

Exposición de Token Operacional y Control de Telemetría mediante JavaScript del Cliente

Identificador de la bandera: UPSLP_CNOIV-OPS-TOKEN-17
Componente afectado: Gateway / Centro de Operaciones – token operacional y scripts de telemetría
Categoría: Information Disclosure / Broken Authentication / IDOR

Descripción técnica y causa raíz

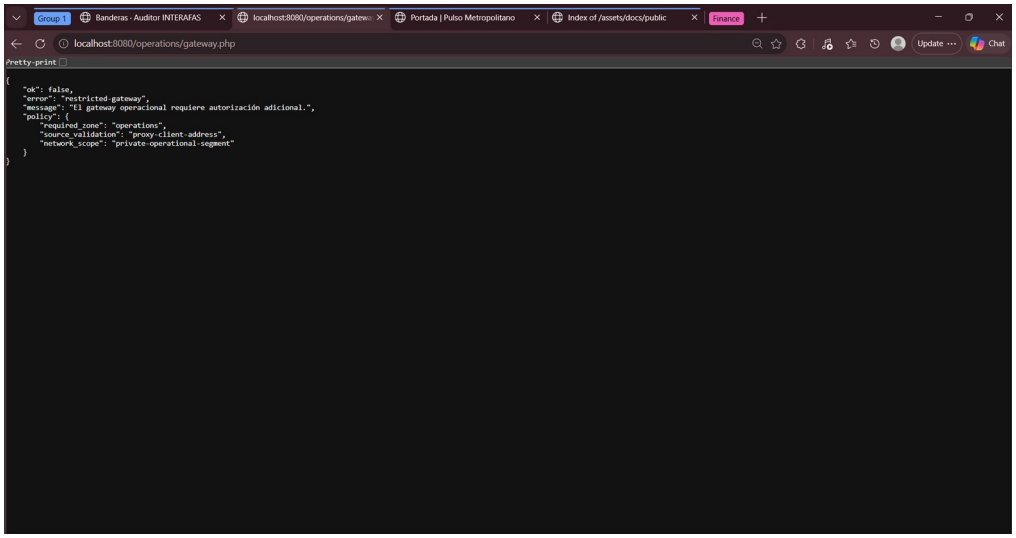
Se identificó que la plataforma de telemetría transfiere la lógica de control hacia el navegador. Los scripts de JavaScript alojados en el cliente no solo exponen un token operacional válido, sino también la estructura de control, rutas (API parameters) y el mecanismo que la interfaz HMI emplea para ejecutar órdenes a los dispositivos. Al comparar las credenciales de sesión normales con los scripts descubiertos, se verifica una completa falta de autenticación a nivel de endpoints operacionales en el backend, lo que faculta a usuarios no privilegiados para accionar actualizaciones y envíos de mandos a equipos OT de campo.

Comprobación de los hallazgos

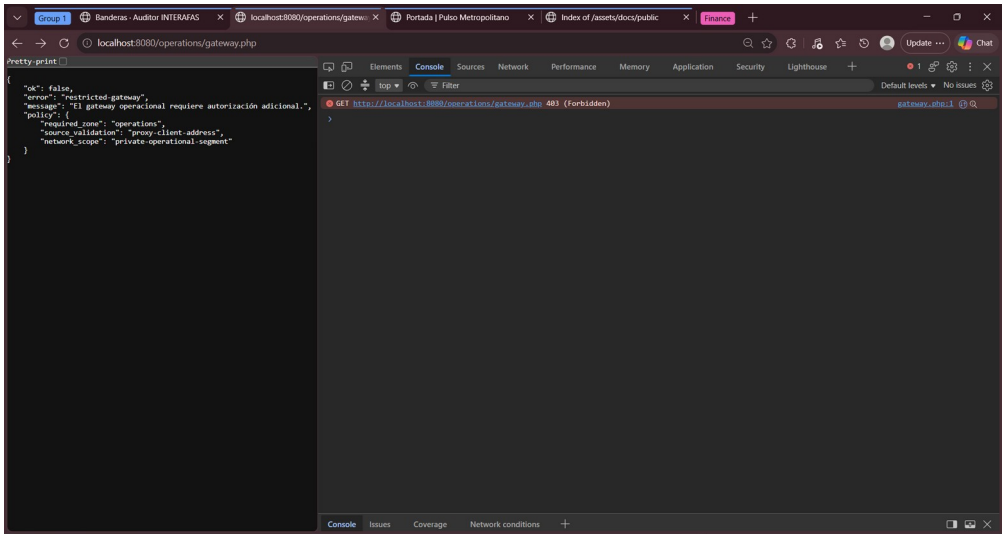
1. Extracción del token operacional expuesto al evadir el Gateway.
2. Depuración de los scripts JavaScript encargados de efectuar el refresco en segundo plano de la telemetría operativa.
3. Aislamiento del control y parámetros que la HMI exige para comunicarse con los equipos remotos.
4. Comprobación de que la autorización para dichas acciones no se exige desde el backend, demostrando la posibilidad teórica de controlar dispositivos.

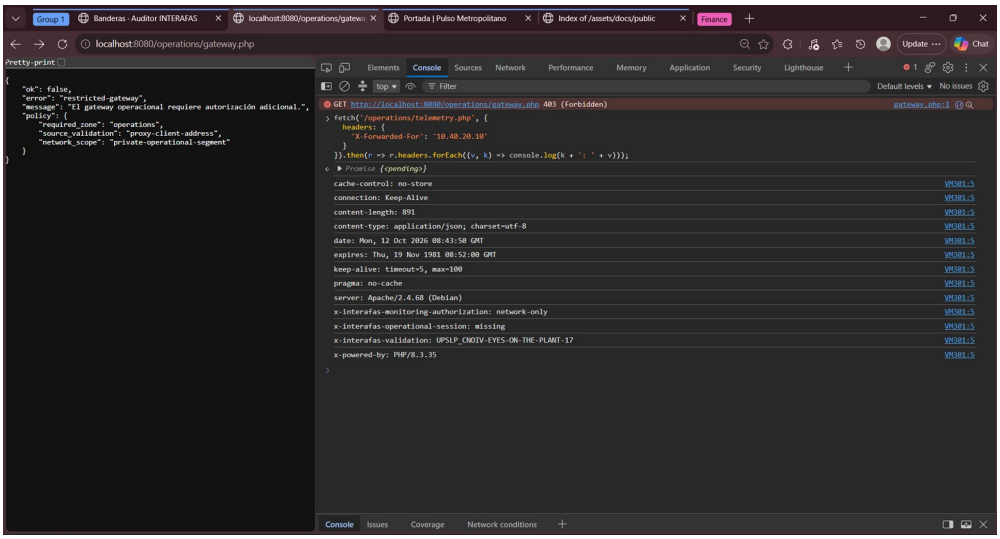
Evidencia técnica

Token operacional expuesto en scripts JavaScript del cliente.



Estructura de control y parámetros utilizados por el HMI.





Demostración de ausencia de autenticación en endpoints operacionales del backend.

Impacto y riesgo

Riesgo Crítico. Vulnerabilidad con implicaciones directas en Tecnologías de la Operación (OT). Permitiría la ejecución no autorizada de acciones de control en la infraestructura crítica de la organización.

Mitigaciones

- Consolidar estrictamente todo mecanismo de control y ejecución operativa en el backend.
- Autenticar de manera fehaciente (Zero Trust) cualquier invocación a las APIs de telemetría.
- Eliminar la existencia de Tokens de autorización embebidos, hardcodeados o filtrados hacia la lógica del lado cliente.
- Limitar al portal público a ser únicamente consumidor de datos de lectura de solo telemetría des-sensibilizada.

Decimoctaba Bandera

Verificación insuficiente de autenticidad en el canal de actualización de firmware y recuperación de credencial de mantenimiento heredada

Identificador de la bandera: UPSLP_CNOIV-FIRMWARE-AUTH-18

Componente afectado: Canal de actualización de firmware / HMI de Operaciones (servicio de manifiesto y endpoint de soporte)

Categoría: Insufficient Verification of Data Authenticity (CWE-345) + Use of a Broken or Risky Cryptographic Algorithm (CWE-327) + Broken Authentication

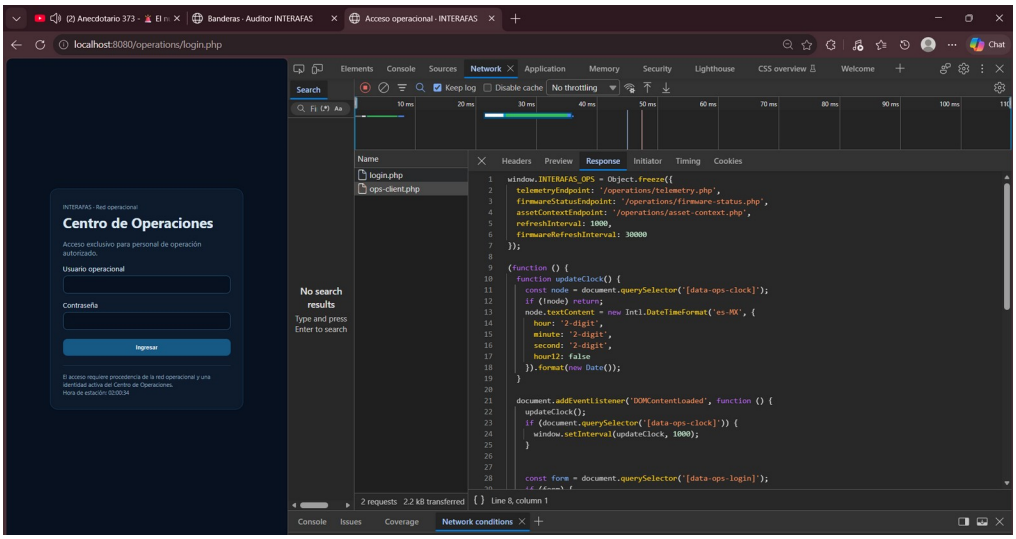
Descripción técnica y causa raíz

A partir del estado de actualización visible en la telemetría se identificó el servicio que el HMI consulta para obtener detalles de firmware. Siguiendo únicamente las rutas declaradas se alcanzó el manifiesto. En los metadatos release y support se localizó una identidad de mantenimiento protegida por un verificador heredado. El verificador fue clasificado offline como SHA-1 (40 caracteres hexadecimales, sin salt). Se conservó el valor original, se normalizó y se sometió a un ataque de diccionario + reglas contextuales derivadas del propio manifiesto. Una vez recuperado el candidato, se validó recalculando el digest. La credencial se utilizó exclusivamente contra el esquema de autenticación y el alcance declarados por support (Basic Auth sobre el canal de firmware). Posteriormente se descargó el paquete aprobado y se demostró que el instalador únicamente comprueba integridad (SHA-256 del payload) pero no verifica una firma digital del emisor, aceptando contenido modificado.

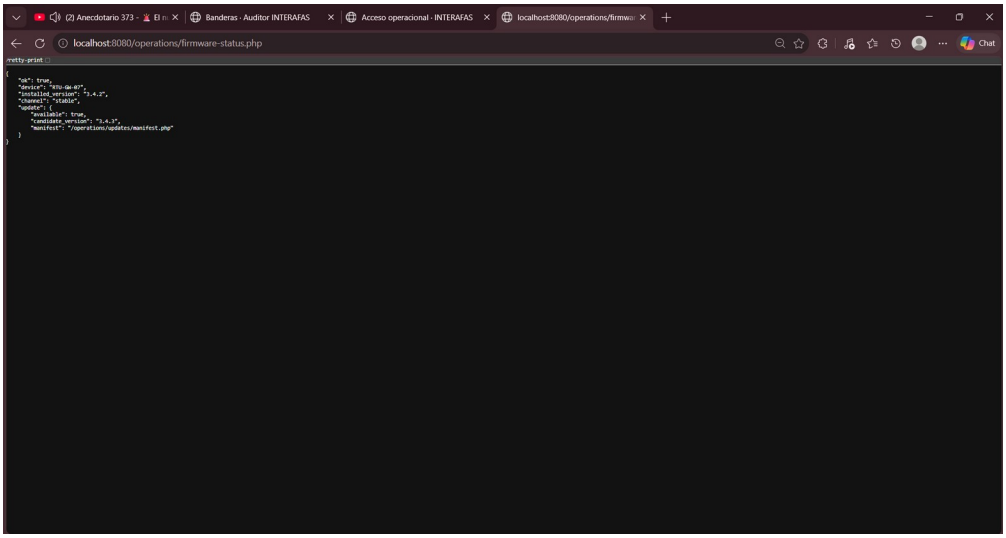
Comprobación de los hallazgos

1. Identificación del servicio de firmware consultado por el HMI desde la telemetría.
2. Extracción y análisis completo del manifiesto (campos release y support).
3. Clasificación del verificador (algoritmo probable, longitud, alfabeto, ausencia de salt) con hashID / hash-identifier.
4. Cracking offline (Hashcat -m 100 o John raw-sha1) usando diccionario + reglas contextuales.
5. Validación del candidato recuperado mediante recálculo del digest.
6. Uso de la credencial únicamente en el endpoint y esquema declarados.
7. Descarga del paquete, modificación controlada del payload, recálculo de SHA-256 y demostración de aceptación sin firma.

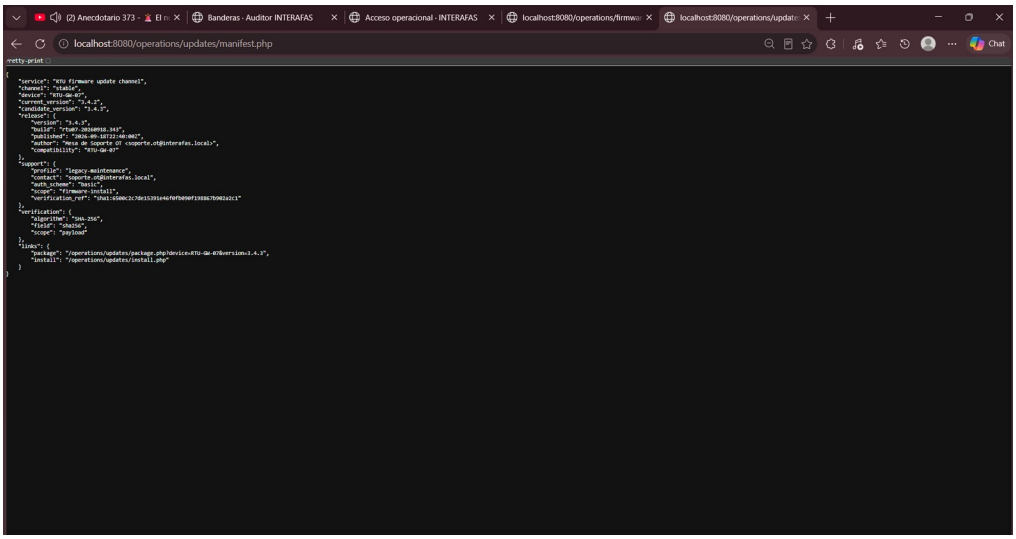
Evidencia técnica



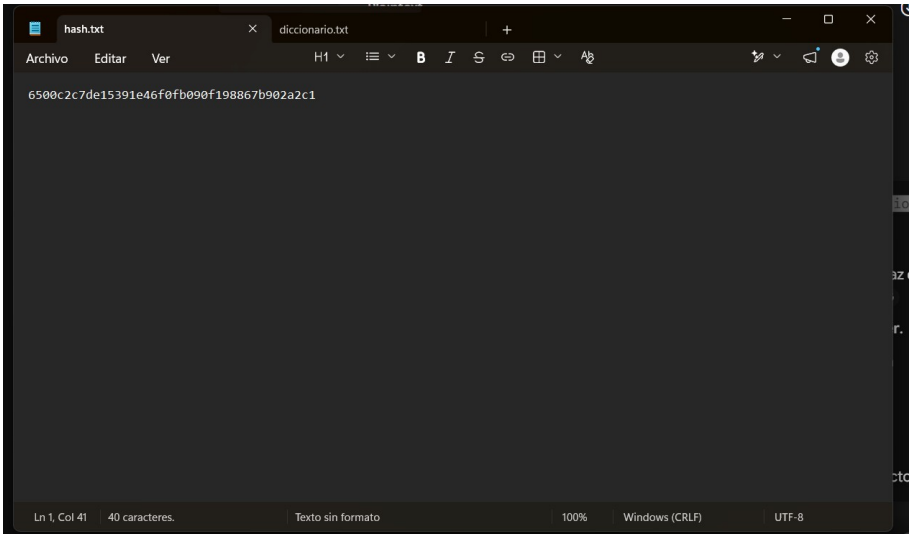
Identificación del servicio de firmware desde la telemetría.



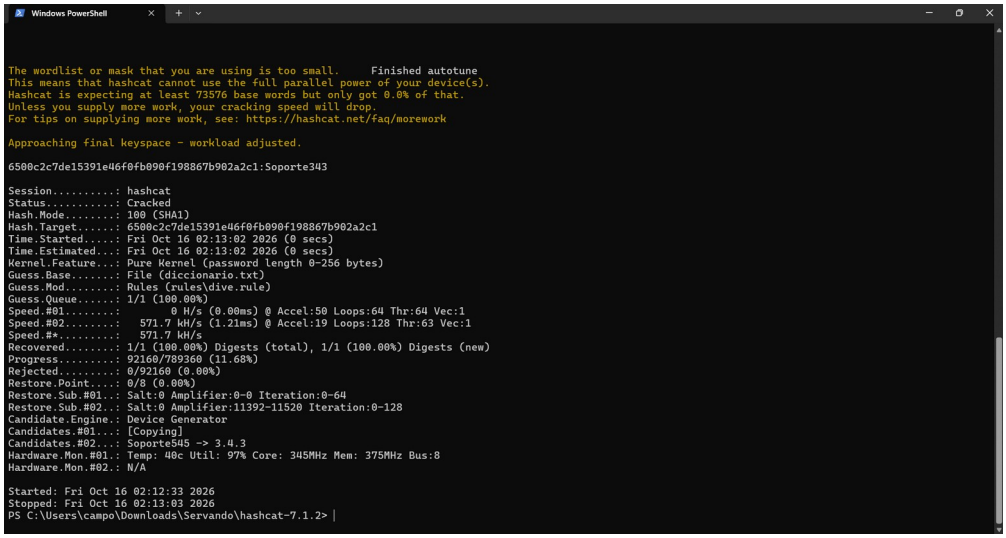
Metadatos release y support del manifiesto.



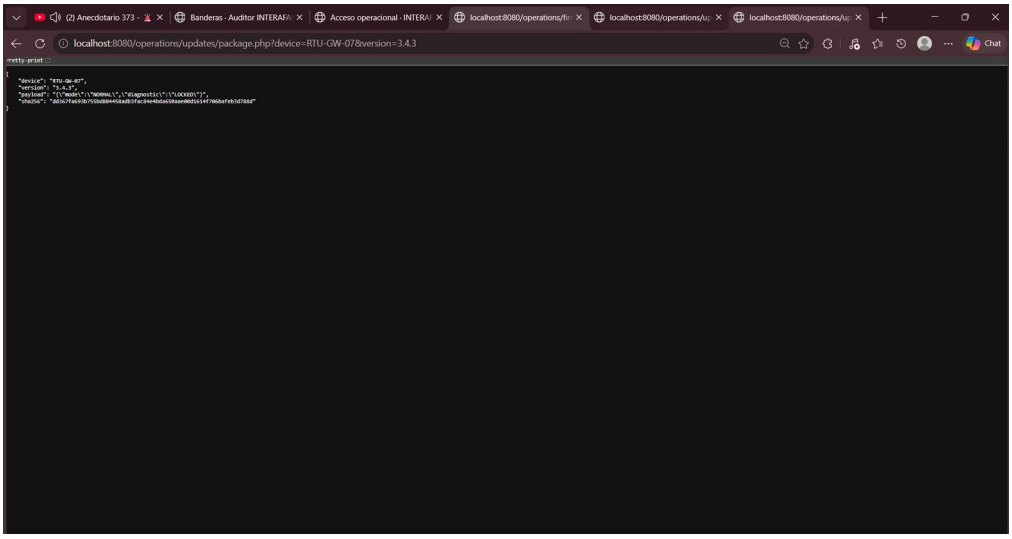
Clasificación del verificador (SHA-1 sin salt).

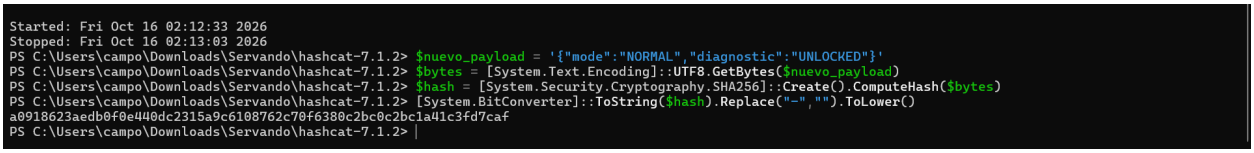


Resultado del cracking offline del hash.



Descarga del paquete de firmware y modificación del payload.





Demostración de que el instalador acepta el contenido modificado solo verificando SHA-256



Resultado de la aparición de la bandera

Impacto y riesgo

Riesgo Crítico. Compromete la autenticidad de las actualizaciones de firmware en un entorno de infraestructura crítica. Un atacante que recupere o posea la credencial de mantenimiento puede distribuir configuraciones o firmware maliciosos que el sistema instalará siempre que el hash coincida. Impacto directo sobre la seguridad física del proceso.

Mitigaciones

- Eliminar el uso de SHA-1 y cualquier hash rápido sin salt para credenciales.
- Implementar firma digital obligatoria (RSA/ECDSA o equivalente) de todos los paquetes de firmware y configuración, con verificación de la clave pública anclada.
- Separar claramente los conceptos de integridad (hash) y autenticidad (firma).
- Rotar y eliminar credenciales estáticas de mantenimiento; preferir autenticación moderna y de corta duración.
- Aplicar el principio de mínimo privilegio y segmentación estricta al canal de actualización.

Decimonovena Bandera

Violación del principio de mínimo privilegio: recorrido completo de la cadena de dependencias OT mediante rol de mantenimiento

Identificador de la bandera: UPSLP_CNOIV-MIN-PRIV-19

Componente afectado: HMI de Ingeniería – Asset Context (asset-context.php) y relaciones entre activos OT

Categoría: Broken Access Control / Excessive Privileges / Violation of Least Privilege

Descripción técnica y causa raíz

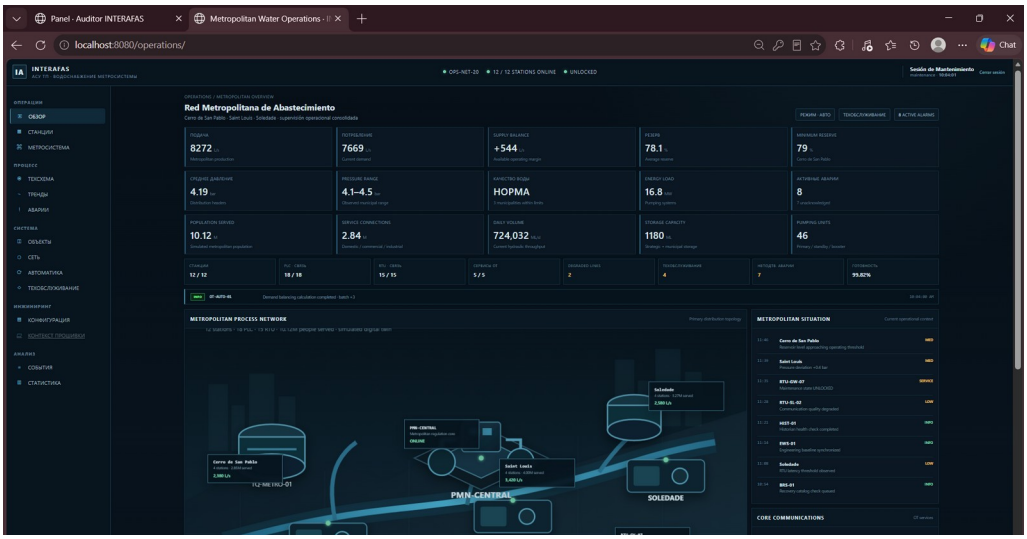
Utilizando la sesión de mantenimiento legítima obtenida en el reto anterior (sin buscar nuevas credenciales ni endpoints ocultos), se accedió al inventario de activos. Al seleccionar el gateway metropolitano RTU-GW-07, el panel Asset Context y la petición a asset-context.php permitieron iniciar el recorrido de la cadena de dependencias. El indicador ЦЕПОЧКА ЗАВИСИМОСТЕЙ guió la secuencia: Gateway/Comunicaciones → Control → Proceso → Distribución → Campo → Zona de Servicio. El servidor no aplicó ningún control de autorización adicional sobre las relaciones consultables por el rol maintenance, permitiendo completar la cadena 6/6 (ЗАВЕРШЕНО). Esto demuestra una clara violación del principio de mínimo privilegio: una identidad de mantenimiento puede mapear toda la topología crítica de la infraestructura.

Comprobación de los hallazgos

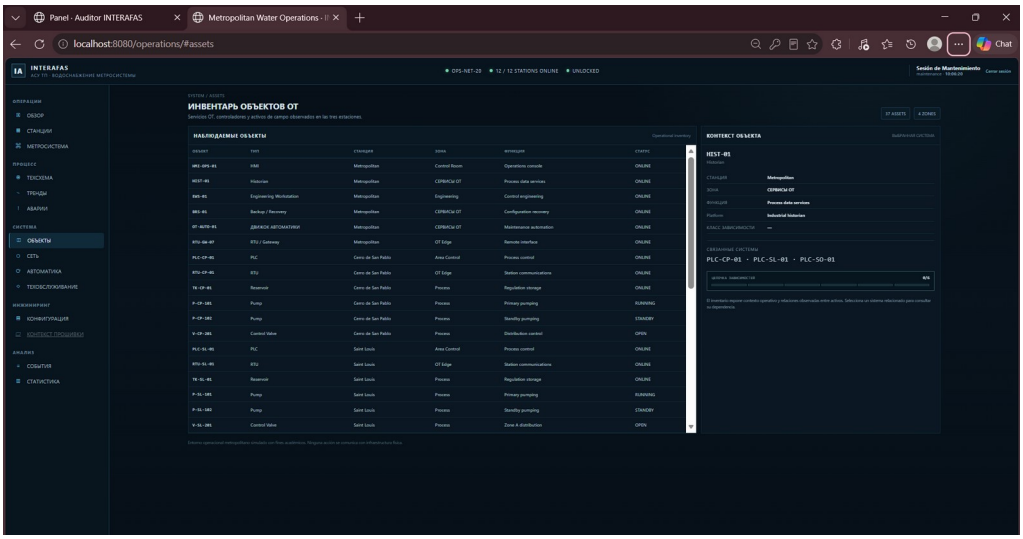
1. Confirmación de sesión de mantenimiento activa.

2. Selección de RTU-GW-07 y verificación del panel Asset Context + petición XHR a asset-context.php.
3. Seguimiento controlado de la cadena utilizando el indicador visual de dependencias.
4. Corrección de saltos incorrectos cuando el indicador pasaba a rojo.
5. Finalización exitosa 6/6 y conservación del JSON de respuesta final junto con los Response Headers.

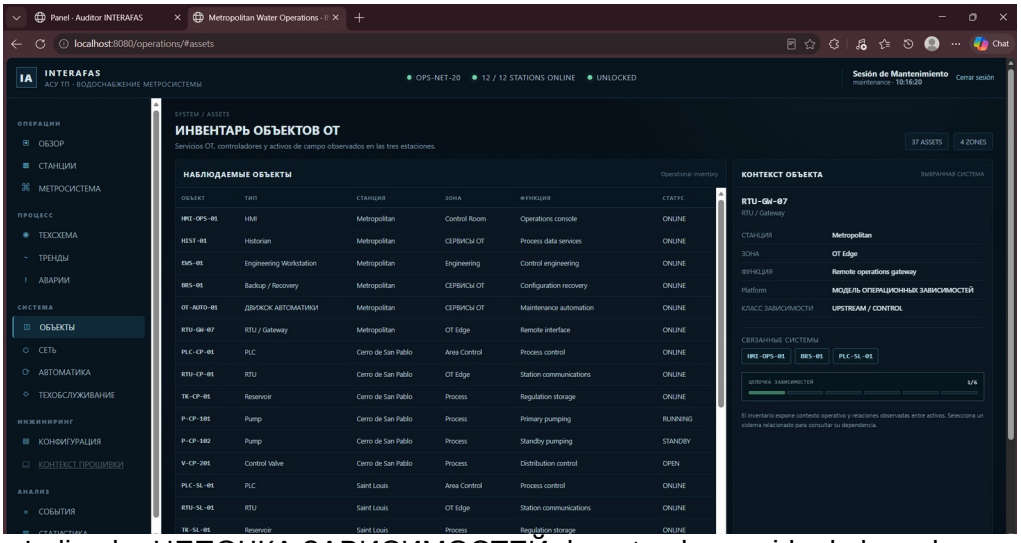
Evidencia técnica



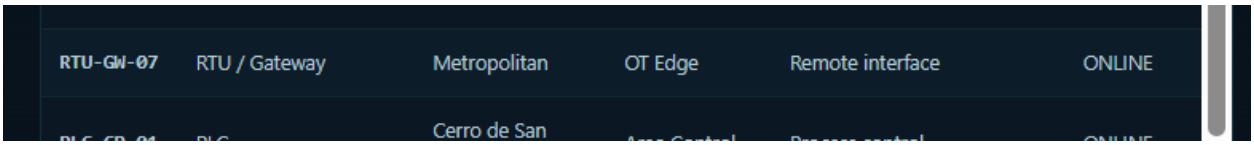
Selección del activo RTU-GW-07 en el HMI.



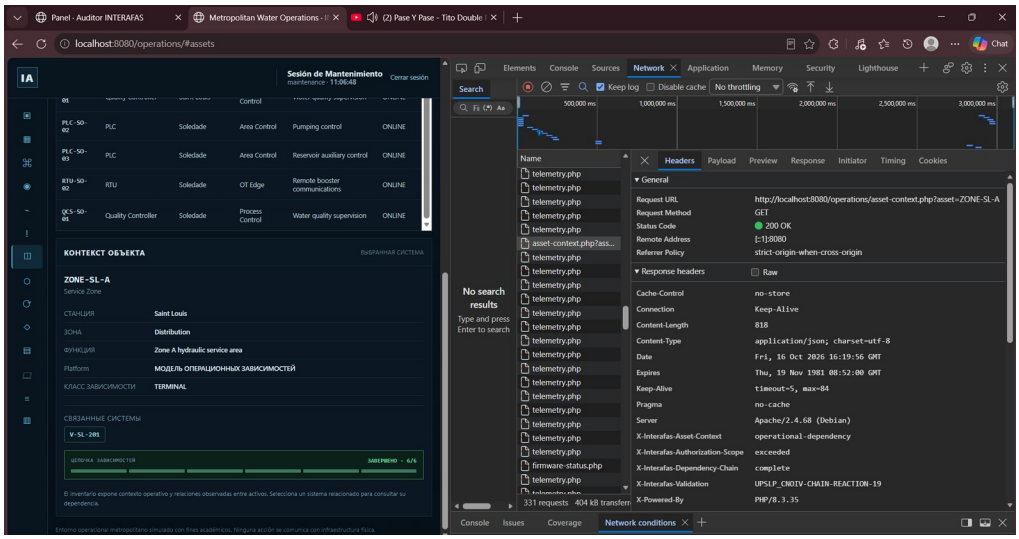
Panel Asset Context y petición a asset-context.php.



Indicador ЦЕПОЧКА ЗАВИСИМОСТЕЙ durante el recorrido de la cadena.



Parte encontrada de RTU-GW-07



Finalización exitosa 6/6 (ЗАВЕРШЕНО) y JSON de respuesta final.

Impacto y riesgo

Riesgo Alto / Crítico en contexto OT. Un usuario con privilegios de mantenimiento puede descubrir y mapear la totalidad de las relaciones entre sistemas de control, proceso y campo. Esta información facilita movimientos laterales, identificación de activos críticos y preparación de ataques de mayor impacto sobre el proceso físico.

Mitigaciones

- Implementar controles de autorización basados en relaciones (ReBAC) o en atributos del activo.
- Aplicar denegación por defecto: el rol maintenance solo debe poder consultar los activos y relaciones explícitamente asignados.
- Registrar y generar alertas ante recorridos completos o inusuales de cadenas de dependencia.
- Revisar y reducir el alcance real del rol de mantenimiento conforme al principio de mínimo privilegio.

Vigésima Bandera

Modificación no autorizada de parámetros operacionales críticos mediante carga de configuración de firmware (Pressure Setpoint)

Identificador de la bandera: UPSLP_CNOIV-NOW-YOU-CONTROL-20

Componente afectado: Módulo Firmware del HMI / RTU-GW-07 – parámetro operacional pressure_setpoint_bar

Categoría: Modify Parameter (MITRE ATT&CK ICS T0836) + Insufficient Verification of Data Authenticity

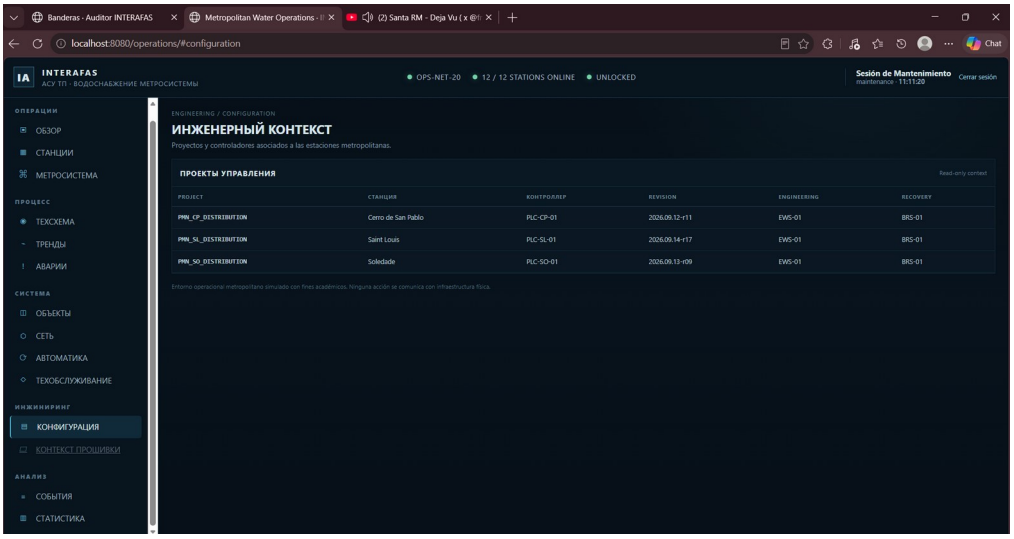
Descripción técnica y causa raíz

Tras completar la cadena de la bandera 19, el menú Firmware se habilita para la sesión de mantenimiento. El sistema permite descargar un archivo de backup de configuración que contiene, entre otros campos, el parámetro operacional pressure_setpoint_bar (baseline de ingeniería: 4.2 bar). Se creó una copia del backup, se modificó exclusivamente dicho parámetro y se volvió a cargar el archivo. El sistema aceptó la configuración sin validar límites de ingeniería ni autenticidad del origen. Esto desencadenó una cascada observable: aumento de presión y caudal, crecimiento del número de alarmas, caída de disponibilidad y propagación progresiva del estado rojo hasta alcanzar CATASTROPHIC STATE, momento en el cual aparece automáticamente la bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20.

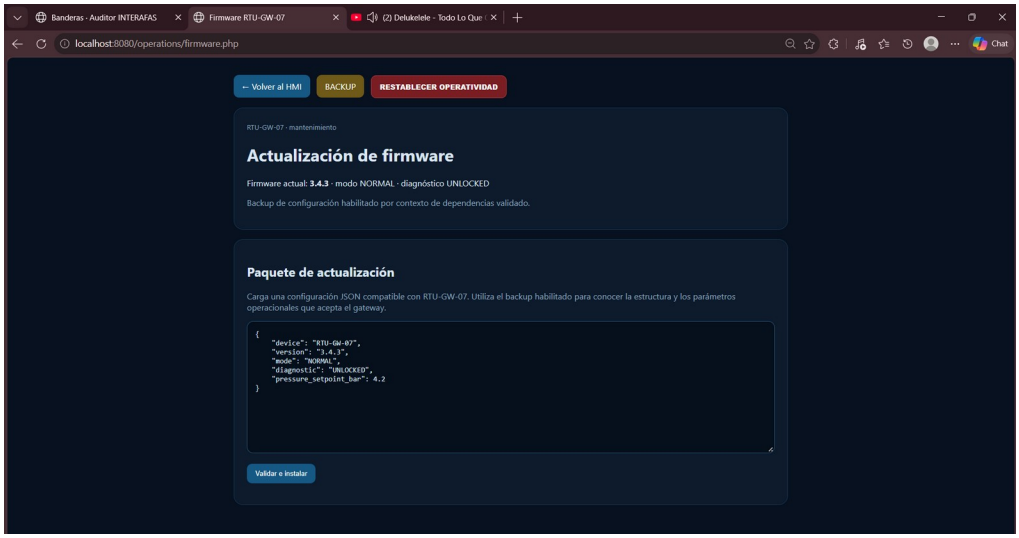
Comprobación de los hallazgos

1. Verificación de que el menú Firmware quedó habilitado tras completar VULN-19.
2. Descarga y conservación del archivo BACKUP original.
3. Modificación controlada únicamente de pressure_setpoint_bar.
4. Carga del JSON modificado y retorno al HMI.
5. Observación de la cascada completa en intervalos aproximados de 3 segundos.
6. Confirmación de la aparición automática de la bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20 en estado catastrófico.

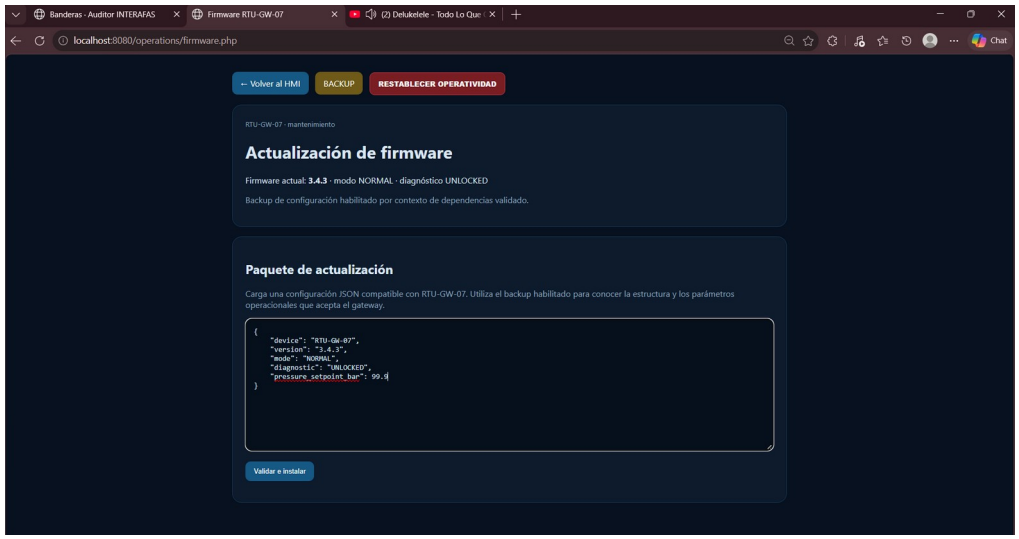
Evidencia técnica



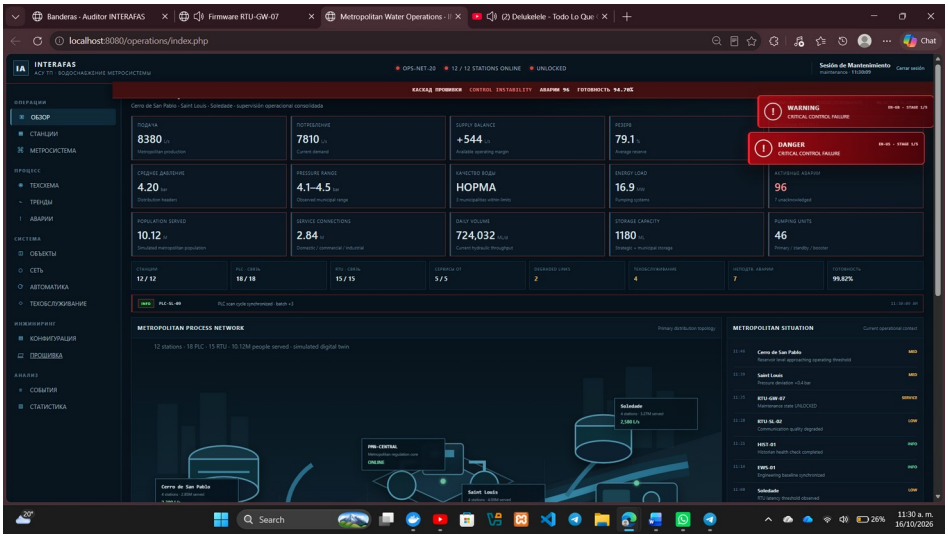
Descarga del archivo BACKUP original de configuración.



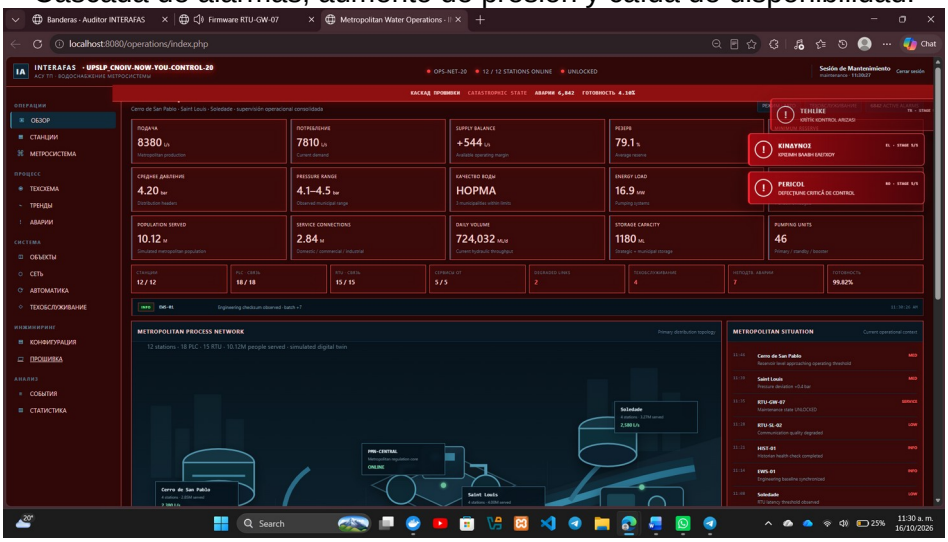
Modificación controlada del parámetro pressure_setpoint_bar.



Carga del JSON modificado en el módulo Firmware.



Cascada de alarmas, aumento de presión y caída de disponibilidad.



Estado CATASTROPHIC STATE con aparición automática de la bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20

Impacto y riesgo

Riesgo Crítico. Impacto directo y demostrable sobre el proceso físico. Un atacante puede provocar condiciones operativas peligrosas (sobrepresión) simplemente modificando un archivo de configuración que el sistema acepta sin controles adecuados de autenticidad ni de validación de rangos de ingeniería.

Mitigaciones

- Validación obligatoria en backend de todos los setpoints contra rangos de ingeniería predefinidos.
- Exigir firma digital y verificación de autenticidad de cualquier archivo de configuración o firmware antes de su aplicación.
- Separar privilegios: la modificación de parámetros críticos debe requerir un rol específico de ingeniería de proceso o aprobación dual.
- Implementar monitoreo continuo de cambios en parámetros críticos y capacidad de rollback automático o safe-mode.
- Aplicar los principios de NIST SP 800-193 (protección, detección y recuperación de firmware).

Análisis de Cadena de Ataque

Los hallazgos no deben interpretarse como vulnerabilidades aisladas. A continuación se describe una cadena de ataque representativa que ilustra cómo una secuencia de fallos técnicos, de control de acceso y de gobernanza puede evolucionar desde el reconocimiento inicial hasta el impacto sobre el proceso físico:

1. Reconocimiento inicial: Exposición de rutas y archivos residuales (Bandera 1), endpoints y metadatos en el frontend (Bandera 2), y archivos .bak (Bandera 4) permiten mapear la superficie de ataque y obtener tokens y rutas internas.

2. Compromiso de la capa de aplicación: IDOR en expedientes y APIs (Banderas 3, 11, 12, 14), escalamiento de privilegios por cookie (Bandera 6), inyección SQL (Bandera 7) y XSS almacenado (Bandera 8) permiten obtener datos sensibles, elevar privilegios y comprometer sesiones de otros usuarios.

3. Acceso al segmento operativo: Bypass del Gateway mediante X-Forwarded-For (Bandera 16) y exposición de token operacional en JavaScript (Bandera 17) facilitan el acceso a zonas de red clasificadas y a capacidades de control.

4. Compromiso del canal de firmware y rol de mantenimiento: Recuperación de credencial heredada SHA-1 y ausencia de verificación de autenticidad del paquete (Bandera 18) permiten obtener una sesión de mantenimiento legítima.

5. Mapeo completo de la topología OT: La violación del principio de mínimo privilegio (Bandera 19) permite recorrer toda la cadena de dependencias desde el gateway hasta la zona de servicio.

6. Impacto sobre el proceso físico: La capacidad de modificar parámetros operacionales críticos (pressure_setpoint_bar) sin validación de autenticidad ni rangos de ingeniería (Bandera 20) conduce a un estado catastrófico del proceso.

Esta cadena demuestra que la seguridad de la infraestructura crítica requiere la integración de controles técnicos, de procesos, de gobernanza y de respuesta, tal como se desarrolla en los entregables de gobernanza ISO 27001, Plan de Comunicación de Crisis y Plan de Respuesta ante Incidentes.

Conclusiones y Recomendaciones Prioritarias

La evaluación de INTERAFAS-LAB reveló un conjunto de vulnerabilidades que, en conjunto, permiten a un atacante pasar del reconocimiento pasivo al impacto directo sobre el proceso físico. Las deficiencias más graves se concentran en:

- Controles de acceso rotos (IDOR, escalamiento de privilegios, mínimo privilegio insuficiente).
- Exposición de información sensible y endpoints internos.
- Ausencia de verificación de autenticidad en el canal de actualización de firmware.
- Validaciones de lógica de negocio insuficientes (pagos, parámetros operacionales).
- Confianza indebida en datos controlados por el cliente (cookies, headers, montos, archivos de configuración).

Se recomienda priorizar las siguientes acciones:

1. Implementar controles de autorización robustos (BOLA/ReBAC) y eliminar cualquier decisión de acceso basada en datos del cliente.
2. Establecer un proceso de actualización de firmware con firma digital obligatoria y validación de rangos de ingeniería.
3. Aplicar el principio de mínimo privilegio de forma estricta a todos los roles, especialmente los de mantenimiento y operaciones.
4. Sanitizar el entorno de producción (eliminación de archivos residuales, desactivación de depuración, ofuscación de frontend).

5. Integrar estos hallazgos en el Sistema de Gestión de Seguridad de la Información (ISO/IEC 27001), el Plan de Comunicación de Crisis y el Plan de Respuesta ante Incidentes.